CISSP Domain 4：通信とネットワークのセキュリティ【統合・追記版】

4.1 ネットワークアーキテクチャへの安全な設計原則の適用

> **更新方針**：このファイルをドメイン4の単一マスターノートとして使用する。今後の読み上げは章ごとに追記・改訂し、別ファイルには分割しない。音声で確認できた事項と、教材未読の先取り補足は区別する。

> **収録範囲と出典上の注意**：会話で確認できる読み上げを主軸に、OSIレイヤー1〜5を統合。欠けた音声部分は一般的なネットワーク標準知識で補足し、教材を実際に読了したとみなさない。レイヤー6〜7は概要のみ。参考： https://tex2e.github.io/blog/security/cissp-notes （章立ては異なるため内容で対応づける）。

学習目的

- OSI参照モデル（7層）とTCP/IPモデル（通常4層）の役割を説明できる。
- 各層の機能、主要技術・プロトコル、脅威と対策を関連づける。
- IP通信の保護、ネットワーク仮想化と物理ネットワークの相違、SDNの基本概念を理解する。
- 脅威モデリング、APT、サイバーキルチェーンをネットワーク防御に応用する。

1. 概要：なぜネットワークモデルが必要か

異なるベンダーのハードウェア・ソフトウェアが相互接続し、データを共有し、処理を協調するには共通の通信ルールが必要。OSIとTCP/IPは、機能を階層（**プロトコルスタック**）に分けて通信を理解・実装するためのモデルである。

- **OSI参照モデル（ISO）**：通信を7つの役割に分解した、分析・教育・設計・障害切り分けに有用な参照モデル。
- **TCP/IPモデル（インターネットプロトコル群）**：実際のインターネット通信を支えるプロトコル群の機能分担を表す。4層モデルが一般的だが、5層で説明する資料もある。
- **重要な違い**：「OSI＝アプリケーション、TCP/IP＝ビット」ではない。**どちらもアプリケーションから通信媒体までを扱う**。OSIは7層に細分化し、TCP/IPは上位機能などをまとめて表現する。
- **ベストエフォート**：IPは基本的に到達・順序・遅延を保証しない。必要な信頼性はTCPなど上位の仕組みが補う。

OSI 7層とTCP/IP 4層の対応【最重要】

OSI層	名称	役割・例	TCP/IP層
L7	アプリケーション	HTTP(S)、DNS、SMTP、アプリケーション向け通信	アプリケーション
L6	プレゼンテーション	データ表現、符号化、圧縮、暗号化の概念	アプリケーション
L5	セッション	セッション確立・維持・終了	アプリケーション
L4	トランスポート	TCP、UDP、ポート番号、エンドツーエンド転送	トランスポート（ホスト間）

OSI層	名称	役割・例	TCP/IP層
L3	ネットワーク	IPv4/IPv6、ルーティング、論理アドレス	インターネット
L2	データリンク	Ethernet、MACアドレス、フレーム、スイッチ	ネットワークインターフェース（リンク）
L1	物理	電気・光・電波、ケーブル、コネクタ、ビット	ネットワークインターフェース（リンク）

暗記：OSI上から「ア・プ・セ・ト・ネ・デ・ブ（物理）」／TCP/IP上から「アプリ・トランスポート・インターネット・リンク」。OSIのL5〜L7がTCP/IPアプリケーション層、L1〜L2がリンク層にまとまる。

6つの基本質問（5W1H）

問い	通信設計で考えること
Who：誰が誰に	送信者・受信者、識別・認証
What：何を	データ内容、形式、機密性・完全性
Where：どこで	アドレス、宛先、経路
Why：なぜ	業務目的、アクセス許可
When：いつ	タイミング、遅延、可用性
How：どうやって	プロトコル、媒体、暗号化、制御

2. インターネットワーキングとカプセル化

インターネットワーキング：異なるネットワークやホストが共通のプロトコル群を用いて相互通信すること。主な考え方は、階層ごとの責務分離、パケットを基礎とする通信、標準化されたアドレス・ルーティング・制御、ベンダー非依存性、拡張性・到達性。

カプセル化：送信時に上位層のデータへ各層の制御情報（ヘッダーなど）を付加して下位層へ渡す。受信側では逆順に取り外す（非カプセル化）。アプリケーション層は一般に上位のネットワーク層からデータを受け取って包むわけではない。

レベル	PDU（一般的な呼び方）	主な識別情報
L7〜L5	データ	アプリケーション固有
L4	セグメント（TCP）／データグラム（UDP）	ポート番号
L3	パケット	IPアドレス
L2	フレーム	MACアドレス
L1	ビット	電気・光・無線信号

イメージ：HTTPデータ → TCPヘッダー付与 → IPヘッダー付与 → Ethernetフレーム化 → ビット送信。実際のプロトコルでは例外や追加のカプセル化もある。

3. なぜ両モデルが必要なのか

- 両モデルの用語が実製品、サービス、運用手順で併用されている。
- OSIは層別の障害分析・脅威整理に便利。TCP/IPは現実のIPネットワークの設計・運用を理解するのに直接的。
- アプリケーション層は複雑で、利用者の認証・権限・データの扱いなどのリスクが集中しやすい。
- 利用者が正規の手順を使いにくいと、非承認の回避策（シャドーITなど）が生まれ、セキュリティが弱まる。
- **ただし「セキュリティは最上位層だけで考える」という意味ではない**。物理からアプリケーションまで多層防御が必要。

4. 脅威モデリングとインターネットワーキング

用語	読み上げ教材での区別	補足
ハザード（Hazard）	意図的な攻撃者によらない損害・混乱の原因	落雷、停電、火災、機器故障など
脅威（Threat）	意図と目的を持つアクターによる損害・混乱の可能性	不正侵入、情報窃取、DDoSなど

注意：一般的なリスク管理の用語では「脅威」に自然災害など非意図的な原因を含める定義もある。試験では問題文が採用する定義・文脈を優先する。

脅威モデリングは、守る資産、信頼境界、攻撃者、攻撃経路、影響、対策を整理する作業。ネットワーク層だけでなく、アプリケーション・認証・運用まで対象にする。

5. 標的型攻撃（APT）とサイバーキルチェーン

APT（Advanced Persistent Threat）：高度な手法を使い、長期間にわたって特定の組織・資産を狙う脅威活動、またはその実行主体を指す。偵察、侵入、潜伏、横展開、目的達成などが継続的に行われる。例として教材では原子力関連組織への攻撃やSolarWindsのサプライチェーン侵害に言及。

サイバーキルチェーン：攻撃を段階に分解し、どこで検知・阻止できるかを考えるモデル。一般にLockheed MartinのCyber Kill Chainとして知られる。段階は直線的に見えるが、実際の攻撃は前後・反復することがある。

フェーズ	攻撃者の典型行動	考えられる兆候（Indicator）	防御・検知例
1. 偵察（Reconnaissance）	OSINT、外部スキャン、対象者・システムの調査	不自然なスキャン、標的型フィッシングの準備兆候	公開情報管理、外部露出管理、IDS/IPS
2. 武器化（Weaponization）	脆弱性に合わせたペイロード・侵入手法の準備	通常は被害組織の内部から直接観測しにくい	脅威インテリジェンス、脆弱性管理
3. 配信（Delivery）	メール、悪意あるURL、USB、サプライチェーン経由	メール検知、危険URL、許可リスト違反	メール保護、Webフィルタ、アプリ制御
4. エクスプロイト（Exploitation）	脆弱性悪用、認証突破、権限昇格、LotL（正規ツール悪用）	EDR・アンチマルウェア警告、異常認証、権限昇格	パッチ、MFA、EDR、最小権限

フェーズ	攻撃者の典型行動	考えられる兆候（Indicator）	防御・検知例
5. インストール（Installation）	バックドア、永続化、悪意ある構成変更	未承認サービス・タスク、構成変更、未知の実行ファイル	変更監視、許可リスト、EDR
6. C2（Command and Control）	外部の攻撃者との指令・通信チャネル確立	不審な宛先、周期的通信、DNS・通信量の異常	DNS監視、出口制御、NDR、プロキシログ
7. 目的の実行（Actions on Objectives）	情報窃取、改ざん、破壊、横展開、痕跡消去	異常なDB照会、転送量、利用者行動、システム動作	DLP、UEBA、SIEM、分離・封じ込め

関連用語

- **OSINT**：Open-Source Intelligence。公開情報を用いた情報収集。
- **LotL / Living off the Land**：OS標準・正規管理ツールを悪用する手法。マルウェアファイルがなくても成立し得る。
- **C2 / C&C**：Command and Control。攻撃者が侵害先へ指示する通信・制御基盤。
- **Indicator / IOC**：侵害の兆候・痕跡。単独で侵害を断定できないものもある。
- **AAA**：Authentication（認証）、Authorization（認可）、Accounting（利用記録）。異常な認証や権限変更は重要な監視対象。
- **SolarWinds事案**：正規ソフトウェアの更新経路が悪用された代表的なサプライチェーン攻撃事例。

6. OSIレイヤー別：仕組み・脅威・対策

L1 物理層【読み上げ内容を再整理・補強】

目的・仕組み：電気・光・電波などの信号を使い、媒体上でビット列を送受信する。電気信号の減衰・雑音・距離制約に対応して符号化、変調、増幅・再生などを行う。PDUは**ビット**。ここでのアドレスはIPやMACではない。

ネットワークトポロジー（物理的な配線構造と論理的な通信経路は異なり得る）：

形状	特徴・用途	長所	注意点
バス型	共通ケーブルを共有、旧式同軸Ethernet	配線が単純	幹線障害・衝突に弱い
スター型	中央スイッチ／ハブに端末を接続	障害切り分け容易	中央装置が障害点
リング型	輪状に接続、旧式Token Ringなど	順番にアクセス制御可能	迂回設計がなければ断線に弱い
ツリー型	スターを階層化した構成	拡張・管理しやすい	上位集約点に依存
メッシュ型	複数経路で相互接続	冗長性・可用性	コストと管理負荷が増大

技術・実装・デバイス：

分類	用語	役割・注意点
媒体	ツイストペア（UTP/STP）	銅線の撚りで干渉を低減。STPはシールド付き。カテゴリと距離制約を確認
媒体	同軸ケーブル	シールドされた銅線。旧式EthernetやCATV等
媒体	光ファイバー（SMF/MMF）	光伝送で長距離・広帯域、電磁干渉に強い。曲げ・物理破損には注意
デバイス	リピーター	信号を再生して距離を延長。通常L1
デバイス	ハブ／コンセントレーター	複数ポートへ信号を中継するL1装置（スイッチと区別）
デバイス	モデム	通信媒体に応じた変調・復調。DSLモデムなど
接続	DSL	既存電話線を使うブロードバンド方式
接続	Ethernet物理規格	銅線・光などの物理層仕様はIEEE 802.3の一部。フレーム／MAC制御はL2
無線	Wi-Fi	IEEE 802.11。無線物理層＋L2 MACを含む
無線	Bluetooth	近距離・省電力向け無線通信
無線	WiMAX	IEEE 802.16系の広域無線アクセス技術
無線	セルラーネットワーク	基地局を用いる広域移動通信（4G/5Gなど）
無線	衛星ネットワーク	広域カバレッジ、災害対策。遅延・天候・端末設置を考慮

脅威と対策：物理切断・盗難・盗聴（タップ）・電磁干渉・妨害電波（ジャミング）・電源障害・自然災害・無線電波の傍受。対策は配線保護、入退室管理、監視、シールド／光ファイバー、冗長経路・UPS、無線暗号化・認証、職員教育。**ウェットウェア**は人間の知識・判断・行動を表す俗称で、教育や手順遵守はL1に限らず全層に関係する。

覚える軸：L1＝媒体・信号・ビット。リピーター／旧式ハブはL1、MAC学習するスイッチは通常L2。

L2 データリンク層【読み上げ内容＋参考資料による補足】

1. 全体像：レイヤー2は何をする？

- **目的**：同一リンク／LAN上でデータを**フレーム（Frame）として届ける。送信元・宛先のMACアドレス**を用い、媒体アクセスを調整し、伝送誤りを検出する。
- **OSI第1層**：ビットを信号として送る。**第2層**：フレームとMACアドレスを扱う。**第3層**：IPアドレスと異なるネットワーク間の経路を扱う。
- **PDU**：フレーム。スイッチが主に利用するのは宛先MACアドレス。IPアドレスによるルーティングとは区別する。
- **注意**：MACアドレスは通常48ビットだが、書き換え・ランダム化・仮想化が可能。世界中で常に一意であることや、認証の根拠になることは保証されない。

2. 二つのサブレイヤー：MACとLLC

サブレイヤー	正式名称	主な役割	覚え方
MAC	Media Access Control（媒体アクセス制御）	MACアドレス、フレーム送受信、媒体へのアクセス方法	**誰に届け、いつ送るか**
LLC	Logical Link Control（論理リンク制御）	上位層との論理的なインターフェース、プロトコルの識別など（IEEE 802.2）	**上位層との橋渡し**

- **48ビットMACアドレス**は6バイト。例：`00:1A:2B:3C:4D:5E`。
- 典型的なグローバル管理アドレスでは先頭24ビットのOUIが製造者を識別するが、現在は複数の割当方式やローカル管理アドレスもある。
- **MAC（媒体アクセス制御）とMAC（強制アクセス制御：Mandatory Access Control）**は同じ略語でも別概念。

3. Ethernet IIフレームの構造

フレーム中の位置（宛先MACから数える）	長さ	フィールド	意味
バイト1〜6	6 B	宛先MAC	届け先のNIC／グループを識別
バイト7〜12	6 B	送信元MAC	送信元を識別
バイト13〜14	2 B	EtherType	ペイロードの上位プロトコルを識別（例：IPv4=`0x0800`、ARP=`0x0806`、IPv6=`0x86DD`）
バイト15以降	通常46〜1500 B	ペイロード＋必要に応じパディング	上位層のデータ
最後の4バイト	4 B	FCS（CRC-32）	伝送中の誤りを**検出**（修復・暗号化はしない）

- **標準Ethernet IIフレーム**は、宛先MACからFCSまで通常64〜1518バイト（VLANタグなし）。物理層のプリアンブル／SFDはこの表に含めない。
- **802.1Q VLANタグ**が入る場合は、送信元MACと元のEtherTypeの間に**4バイト**が挿入される（一般的なタグ付きフレームは最大1522バイト）。
- 参考：Ethernetのペイロードが短い場合はパディングで最小フレーム長を満たす。

4. 重要プロトコル：ARP・PPP・PPPoE

項目	ARP	PPP	PPPoE
正式名称	Address Resolution Protocol	Point-to-Point Protocol	Point-to-Point Protocol over Ethernet
何をする？	**IPv4アドレスから同一リンク上のMACアドレスを解決**	2点間リンクで複数のネットワーク層プロトコルを運ぶ	Ethernet上に論理的なPPPセッションを構築

項目	ARP	PPP	PPPoE
代表的な用途	LANでの次ホップMAC解決	専用線・シリアルリンクなど	ISPアクセス、旧来のブロードバンド接続など
セキュリティ上の注意	**ARPスプーフィング／ARPポイズニング → MITM**	認証方式（PAP/CHAPなど）の安全性に依存	PPP認証に加えセッション・アクセス制御が重要
一言で	**IP→MACを調べる**	**2点間で運ぶ**	**Ethernet上でPPPを使う**

ARPの流れと攻撃

1. 端末Aが同一LAN内の次ホップIPv4アドレスに対応するMACを知りたい。
2. ARP Requestをブロードキャストし、対象端末／ゲートウェイがARP Replyで応答。
3. 端末Aは結果をARPキャッシュに保持し、以後そのMAC宛てにフレームを送る。
4. 攻撃者が偽のARP Replyを流すと、端末Aが**ゲートウェイのIPアドレス＝攻撃者のMACアドレス**と誤認し、**中間者攻撃（MITM）**に誘導されることがある。

対策：DHCP Snoopingと組み合わせた**Dynamic ARP Inspection（DAI）**、信頼できるポート設定、ネットワーク分離、TLS等のエンドツーエンド暗号化。静的ARPは限定的な環境では有効だが大規模運用に不向き。

補足：ARPはIPv4用。IPv6のアドレス解決は通常**NDP（Neighbor Discovery Protocol）**を使用する。ARPを単純に「IPをMACへ変換する暗号化プロトコル」と考えない。

Fibre Channel（FC）とFCoE

技術	説明	主な用途・注意点
FC（Fibre Channel）	ストレージ接続向けの高速・低遅延な通信技術	SAN。専用のFCファブリックを構成できる
FCoE（Fibre Channel over Ethernet）	FCフレームをEthernet上にカプセル化	LAN/SANの配線集約。損失抑制を重視するData Center Bridging等の設計が重要

- **Fibre Channelは「光ファイバーだけを使う」ことを意味しない**。名称と物理媒体を混同しない。
- **QoS（Quality of Service）**は通信品質の制御。ストレージでは遅延・損失・帯域の安定性が重要。

5. 負荷管理・媒体アクセス制御

方式	動作	長所	短所・例
ポーリング方式	制御側が端末に送信機会を順番に与える	衝突や送信機会を管理しやすい	制御のオーバーヘッド、中央制御への依存
競合方式	端末が媒体の空きを確認して送信を試みる	柔軟で分散的	同時送信への対処が必要
CSMA/CD	Carrier Sense Multiple Access with **Collision Detection**：衝突を検出し再送	従来の**半二重・共有媒体Ethernet（IEEE 802.3）**	現代の**全二重スイッチドEthernetでは通常不要**

方式	動作	長所	短所・例
CSMA/CA	Carrier Sense Multiple Access with **Collision Avoidance**：衝突を事前に回避しようとする	**Wi-Fi（IEEE 802.11）**に適合	無線では衝突検出が難しく、バックオフやACK等が必要

暗記：`CD = Detect（起きた衝突を検出）`、`CA = Avoid（起こさないよう回避）`。

6. デバイス：ブリッジ・スイッチ・VLAN

項目	機能	ポイント
ブリッジ	複数のLANセグメントをL2で接続し、MACに基づいて転送・フィルタリング	初期の少数ポート接続の代表例
L2スイッチ	多数のポートを持つ高速なマルチポートブリッジ	MACアドレステーブル（CAM/FDB）を学習して転送
VLAN	物理スイッチ上で**論理的にブロードキャストドメインを分割**	IEEE **802.1Q**タグを利用。VLAN間通信には通常L3ルーティングが必要

- **アクセスポート**：通常1つのVLANの端末を接続。**トランクポート**：複数VLANのタグ付きフレームを運ぶ。
- VLANは**分離の仕組み**だが、単独で強力な認証や暗号化を提供するわけではない。
- スイッチは送信元MACを学習し、宛先MACが不明な場合は該当VLAN内に**Unknown Unicast Flooding**することがある。
- **STP/RSTP**はL2のループを抑制する仕組み。ブロードキャストストーム対策に重要。

7. 脅威と対策：5種類を区別する

攻撃	やさしい意味	何が起こる？	主な対策
MACスプーフィング／クローニング	他端末のMACアドレスに**なりすます／複製する**	MACベース制限の回避、通信の混乱	**802.1X認証**、Port Security、NAC、監視。MAC制限だけを認証とみなさない
MACフラッディング	**偽の送信元MACを大量送信**する	CAMテーブル枯渇や異常転送を狙い、環境によっては盗聴の機会を作る	**Port Security**、MAC学習数制限、異常検知
VLANホッピング	**本来属さないVLANへ侵入**する	スイッチスプーフィング、二重タグ付け等で分離を回避	DTP無効化、アクセスポート固定、未使用ポート停止、ネイティブVLANとトランク設定の適正化
ブロードキャストストーム	ブロードキャストが**大量に増殖・流入**する	帯域・機器CPUを圧迫しDoS。L2ループが典型原因	**STP/RSTP**、Storm Control、ループ防止、VLAN分割
MACスニッフィング／偵察	LANのフレームを**観察・収集**する	通信相手や構成の把握、機密情報漏えい	暗号化、ポート・物理アクセス制御、ミラーポート管理、IDS/IPS

混同しやすい攻撃の差

- **スプーフィング**：他人の**ふりをする。**
- **クローニング**：他人のMACを**複製して使う**（実務上スプーフィングと重なる）。
- **フラッディング**：大量のフレームを**送りつける。**
- **スニッフィング**：流れるフレームを**観察・盗聴する。**
- **VLANホッピング**：VLANという**境界を越える。**
- **MACフラッディング ≠ ブロードキャストストーム**：前者は主に**MAC学習テーブル**を狙い、後者は**大量ブロードキャストによるネットワーク負荷**が中心。
- **ARPポイズニング ≠ MACフラッディング**：前者は**IPとMACの対応関係**を偽り、後者は**MAC学習テーブル**を狙う。

8. 対策の実装ポイント

守る対象	推奨対策	防ぐ／軽減する問題
端末の接続	**802.1X、NAC、Port Security、未使用ポート無効化**	無許可端末、MACなりすましの一部
ARP／DHCP	**DHCP Snooping、DAI、IP Source Guard**	不正DHCP、ARPポイズニング、IPなりすましの一部
VLAN／スイッチポート	**アクセスポート固定、不要なトランク禁止、DTP無効化、適切なネイティブVLAN設定**	VLANホッピング、設定ミス
L2ループ・過負荷	**STP/RSTP、BPDU Guard、Storm Control**	ループ、ブロードキャストストーム
検知と通信保護	**L2監視、IDS/IPS、ログ収集、TLS等の暗号化**	偵察、盗聴、異常な通信

> **CISSP的な考え方**：特定の攻撃への単一対策だけでなく、認証・適切な設定・セグメンテーション・監視・暗号化を組み合わせる「多層防御」で考える。

9. 試験直前チートシート

キーワード	一発で思い出すこと
OSI L2	**フレーム／MACアドレス／スイッチ**
MAC	媒体アクセス制御、通常48ビット（6バイト）
LLC	論理リンク制御、上位層との橋渡し
Ethernet II	宛先6B＋送信元6B＋EtherType2B＋データ＋FCS4B
CRC／FCS	**誤り検出。**暗号化でも訂正でもない
ARP	**IPv4 → 次ホップMAC。**偽応答でMITM
PPP	ポイントツーポイント通信
PPPoE	Ethernet上でPPPセッション

キーワード	一発で思い出すこと
FC／FCoE	ストレージSAN／Ethernet上にFCを載せる
CSMA/CD	**衝突検出**。802.3、従来の半二重Ethernet
CSMA/CA	**衝突回避**。802.11、Wi-Fi
ブリッジ／スイッチ	L2でMACを使って転送。スイッチは多ポートブリッジ
VLAN／802.1Q	論理的なブロードキャストドメイン分割／VLANタグ
MACスプーフィング	MACのなりすまし
MACフラッディング	大量の偽MACで学習テーブルを狙う
VLANホッピング	別VLANへの不正アクセス
ブロードキャストストーム	大量ブロードキャスト。STP、Storm Control
スニッフィング	通信の観察・盗聴
DHCP Snooping＋DAI	不正DHCP／ARPポイズニング対策
802.1X	端末のネットワーク接続認証

10. 理解度チェック（5問）

1. **IPv4アドレスからMACアドレスを調べる仕組みは？** → ARP。
2. **同じスイッチ上で部署別にブロードキャストを分ける仕組みは？** → VLAN。
3. **無線LANで衝突回避を試みる方式は？** → CSMA/CA。
4. **大量の偽MACアドレスでスイッチの学習テーブルを狙う攻撃は？** → MACフラッディング。
5. **ARP偽応答を使って通信経路に割り込む攻撃は？** → ARPポイズニングを用いたMITM。

11. 参考資料・注記

- 読み上げ教材：Domain 4.1「OSIレイヤー2：データリンク層」（本ノートの主軸）。
- CISSP 勉強ノート｜晴耕雨読：「5-3. OSI第2層：データリンク層」。MAC、ARP、CSMA/CD・CA、各種L2攻撃の整理を参照。
- **追加補足**：Ethernetフレーム長、EtherType例、802.1Qタグ、DAI／DHCP Snooping、STP／Storm Control、802.1Xなどは理解を補うための説明。
- **表現上の注意**：「ARPは最重要L2プロトコル」は教材の重点づけ。ARPはIPv4とL2の境界に位置するアドレス解決プロトコルであり、厳密な層分類は説明方法により異なる。「VLANホッピング＝802.1Q攻撃」と限定せず、スイッチスプーフィング等も含めて理解する。

L3 ネットワーク層【読み上げ完了・詳細統合】

目的・アーキテクチャ：論理アドレス（IP）を使って異なるネットワーク間で**パケット**を転送する。ルーターは宛先IPとルーティングテーブルに基づき次ホップを選ぶ。L2のMACアドレスは**同一リンク内のフレーム配送**、L3のIPアドレスは**ネットワークを越える配送**に使う。ルーターを通るたびに通常L2フレームは作り直されるが、IPの送信元／宛先はNAT等がない限り維持される。L3のPDUはパケット。

通信形態：

形式	配送先	用途・例	利点と注意点
ユニキャスト	1対1	Webアクセス	宛先ごとに送るため多数配信は帯域消費
ブロードキャスト	同一ブロードキャストドメインの全員	IPv4 ARPなど	発見に便利、過剰送信で負荷。IPv6にブロードキャストはない
マルチキャスト	参加したグループ	映像配信、経路制御	多数配信に効率的、グループ管理が必要
エニーキャスト	同一アドレスを持つ複数拠点のうち経路上選ばれた1拠点	CDN、DNS	近接／経路最適化、経路変動・状態管理に注意
ジオキャスト	地理的範囲内の対象	地域警報、車車間通信	地域限定に有用、位置情報・対応基盤が必要

IPv4／IPv6と移行：

比較	IPv4	IPv6
アドレス	32ビット、例 `192.0.2.1`	128ビット、例 `2001:db8::1`
表記	10進数4オクテット	16進数8組、省略記法あり
配送	ユニキャスト・ブロードキャスト・マルチキャスト	ユニキャスト・マルチキャスト・エニーキャスト（ブロードキャストなし）
近隣解決	ARP	ICMPv6のNeighbor Discovery（NDP）
セキュリティ	IPsec利用可能	IPsecを利用可能だが、**IPv6自体が自動で暗号化するわけではない**
注意	NATやアドレス枯渇	アドレス範囲・拡張ヘッダー・NDP・IPv6対応FWを管理

移行戦略：**ネイティブIPv6**（内部をIPv6に対応）、**デュアルスタック**（IPv4とIPv6を併用）、**トンネリング**（一方のパケットを他方にカプセル化）、**エッジIPv6**（対外向けをIPv6で提供し内部は変換／中継など）。それぞれ運用の複雑性・可視性・セキュリティポリシーの一貫性に注意。IPv6仕様の初期標準化は1990年代半ば。

IPv4アドレス分類（旧クラスフル方式：現代はCIDRが基本）：

クラス	先頭オクテット	旧デフォルトマスク	典型用途
A	1–126	/8	大規模ユニキャスト（0、127は特殊）
B	128–191	/16	中規模ユニキャスト
C	192–223	/24	小規模ユニキャスト
D	224–239	該当なし	マルチキャスト
E	240–255	該当なし	予約・実験用途

RFC 1918のプライベートアドレス：`10.0.0.0/8`（10.0.0.0〜10.255.255.255）、`172.16.0.0/12`（172.16.0.0〜172.31.255.255）、`192.168.0.0/16`（192.168.0.0〜192.168.255.255）。教材読み上げの「25.25」等は末尾`255.255`の誤認として補正。アドレス割当の全体調整はIANA／ICANN、地域割当はRIR等が担う。

デバイス・アクセス制御：

機器・機能	役割	セキュリティ上の焦点
ルーター	ネットワーク間転送・経路選択	ACL、経路認証、管理プレーン保護
境界ルーター	組織と外部ネットワークの境界	送信元詐称防止、フィルタリング、冗長化
L3スイッチ	スイッチングとIPルーティング	VLAN間ルーティングとACL
ファイアウォール	ポリシーに従う通信制御	L3/L4条件、ステート、場合によりL7検査
ネットワークACL	IP、プロトコル、ポート等の条件で許可／拒否	最小権限、暗黙deny、ルール順序

注意：ネットワークACLと、ユーザーID・ファイル等に結びつくアクセス制御リストは「許可／拒否を記録する」という概念は共通でも、対象と評価条件が異なる。

ルーティング：スタティックルートは管理者が設定。ダイナミックルーティングはルーターが経路情報を交換して更新。標準仕様はRFC等で公開される。

分類	仕組み	代表例・要点
Distance Vector	隣接ルーターから距離・方向を学ぶ	RIP（ホップ数）、収束やループに注意
Link State	ネットワークのリンク状態を共有し最短経路計算	**OSPF**、IS-IS。SPF（Dijkstra）を利用
Path Vector	到達先までの経路属性を交換	**BGP**。AS_PATH等でポリシー制御
IGP／EGP	自AS内／AS間の経路制御	OSPF・RIPはIGP、BGPはEGP
クラスフル／クラスレス	マスク情報を伝達しない／伝達する	RIPv1はクラスフル、RIPv2・OSPF・BGPはクラスレス
Routed Protocol	実際のデータを運ぶ対象プロトコル	IPv4、IPv6（Routing Protocolと区別）

MPLS（Multiprotocol Label Switching）：IPの宛先だけでなく短い**ラベル**を使って転送する技術（L2.5と呼ぶこともある）。**LER／エッジノード**はラベルの付与・除去、**LSR**はラベル交換、**LSP（Label Switched Path）**はラベル転送経路。トラフィックエンジニアリング、VPN、QoS、マルチサービス網、冗長経路に活用。**MPLS自体は暗号化ではない**。SD-WANは別のオーバーレイ制御技術で、同一概念ではない。

ICMP／IGMP：ICMPはエラー通知・診断（ping、tracerouteの一部）、IGMPは**IPv4マルチキャストグループ参加管理**。両者は通常の意味での経路計算プロトコルではない。IPv6ではICMPv6とMLDを使用。

脅威・攻撃と対策：

脅威	攻撃の仕組み・影響	主な対策

脅威	攻撃の仕組み・影響	主な対策
ルーティング攻撃	偽経路・経路ハイジャック・ループ・ブラックホール	ルーティング認証、経路フィルタ、RPKI（BGP）、監視
ICMP悪用	大量ICMPや不正制御メッセージ	レート制限、必要なICMPを選択許可、監視
Ping Flood	ICMP Echoを大量送信しDoS	DDoS対策、レート制限、上流で緩和
Smurf攻撃	被害者IPを送信元に詐称してブロードキャスト宛ICMP Echoを送信、応答を被害者に集中させる	**Directed Broadcast無効化**、送信元検証（BCP 38）、レート制限
IPスプーフィング	偽の送信元IPを用いてなりすまし・反射攻撃	ingress/egressフィルタ、uRPF、認証
パケットスニッフィング	通信経路上のパケットを取得	TLS/IPsec、ネットワーク分離、物理・L2対策

補足：VLAN構成やL2 IDS/IPSは主としてL2対策、マイクロセグメンテーション・ゼロトラストは複数層にまたがる設計原則。ICMPを全遮断するとPath MTU Discovery等が壊れるため必要なメッセージを許可する。

試験での区別：ARP spoofingは主にL2、SmurfはL3（ICMP＋IPv4ブロードキャスト）、SYN floodはL4（TCP）。

L4 トランスポート層【読み上げ完了・詳細統合】

目的・アーキテクチャ：ホスト上のアプリケーション間のエンドツーエンド通信を、**ポート番号**で多重化／逆多重化する。TCPは順序・確認応答・再送・フロー制御・輻輳制御を備える。UDPは小さなヘッダーでデータグラムを送るが、到達・順序・再送をプロトコル自体では保証しない。QoSは複数層の仕組みを組み合わせて実現する。

観点	TCP	UDP
通信	コネクション型	コネクションレス型
確立	3-way handshake：SYN → SYN/ACK → ACK	ハンドシェイク不要
PDU	セグメント	データグラム
信頼性	シーケンス番号、ACK、再送	必要ならアプリケーションが実装
順序保証	あり	なし
主な用途	HTTPS（HTTP/1.1・HTTP/2）、SSH、SMTP	DNSの多くの問い合わせ、音声・映像、QUIC（HTTP/3）
弱点	接続状態の負荷、SYN flood	送信元詐称、反射増幅攻撃、損失・順序入替

ポートとソケット：TCP/UDPヘッダーの送信元／宛先ポートはそれぞれ**16ビット**。ポートは**IPアドレスの一部ではない**。ソケットのエンドポイントは概念的にIPアドレス:ポート番号、接続は通常送信元IP・送信元ポート・宛先

IP・宛先ポート・プロトコルで識別。HTTPSの典型的な宛先ポートは443だが、送信元は一時ポートであり、HTTP/3はUDP/443を使用する。

ポート範囲（IANA）：

範囲	名称	意味
0–1023	Well-Known	代表的な標準サービス用。0は通常一般サービスとして使わない
1024–49151	Registered	IANA登録ポート。登録＝安全性保証ではない
49152–65535	Dynamic/Private	一時的な送信元ポート等に利用。OSの実際のエフェメラル範囲は異なることがある

プロトコル・サービスと主要ポート（試験頻出を優先。アプリケーション層のプロトコルも、L4ポートを使うため一緒に比較）：

プロトコル	主な用途	TCP	UDP	代表ポート・注意点
FTP	ファイル転送（平文）	✓	—	21制御、20はアクティブモードのデータ送信元で使用
SSH / SFTP	暗号化リモート操作・ファイル転送	✓	—	22
Telnet	平文リモート操作	✓	—	23（SSH推奨）
SMTP	メール送信	✓	—	25（サーバー間）、587（Submission）
DNS	名前解決	✓	✓	53（通常UDP、ゾーン転送や大きい応答等TCP）
DHCPv4	動的IP設定	—	✓	67サーバー／68クライアント
TFTP	簡易ファイル転送	—	✓	69（暗号化なし）
HTTP	Web通信	✓	—	80
HTTPS	TLS保護されたWeb通信	✓	✓	443（TCPのHTTP/1.1・2、UDPのHTTP/3/QUIC）
POP3 / POP3S	メール受信	✓	—	110 / 995
IMAP / IMAPS	メール同期・受信	✓	—	143 / 993
LDAP / LDAPS	ディレクトリ照会	✓	✓	389 / 636（実装によりUDPのLDAP利用あり）
NTP	時刻同期	—	✓	123
SNMP	ネットワーク監視	—	✓	161照会／162通知（一般的構成）
BGP	AS間ルーティング	✓	—	179
RADIUS	認証・認可・アカウンティング	—	✓	1812認証／1813アカウンティング（従来の別番号にも注意）

プロトコル	主な用途	TCP	UDP	代表ポート・注意点
Microsoft SQL Server	DB接続	✓	✓	1433/TCP、1434/UDP（Browser）
Docker API	コンテナ管理API	✓	—	2375平文、2376 TLS（公開範囲に厳重注意）
Time Protocol	時刻情報	✓	✓	37（NTPとは別）

用語補足：FTPとSFTPは別方式。DNS・LDAP・NTP・DHCP・HTTP(S)・メール・SSH等は通常OSI上位層のサービス／プロトコルであり、教材の「トランスポート層のプロトコル群」という分類は**ポートを使う関連サービスの整理**と理解する。RIPはUDP/520を使うが**ルーティングプロトコル**。APIはソフトウェア間の機能呼び出しのインターフェースで、特定レイヤー専用の技術ではない。

ファイアウォール／技術と実装：パケットフィルタはIP・ポート・プロトコルで通信を許可／拒否。ステートフルFWは通信状態を追跡し戻り通信を判断。NGFWはアプリ識別・侵入防止等も統合。ネットワーク機器、ホストOS、仮想アプライアンス、クラウドFWで実装できる。TCP InterceptやSYN CookieはSYN flood対策の例。

脅威と対策：

脅威	内容	代表的な対策
TCP SYN flood	半開接続を大量生成し資源枯渇	SYN Cookies、TCP Intercept、DDoS対策
TCPシーケンス予測／セッション乗っ取り	番号を推測して偽パケットを注入	予測困難な初期シーケンス番号、TLS、フィルタ
UDP flood／反射増幅	UDPの大量送信・送信元偽装	レート制限、送信元検証、反射元の設定改善
ポートスキャン	開放サービスを列挙	FW、IDS/IPS、不要ポート閉鎖、監視
NTP操作	時刻同期を妨害・偽装	認証された時刻同期、NTP制限、監視
スニッフィング	平文通信・認証情報を傍受	TLS、SSH、SFTP、セグメンテーション
ICMP flood・経路攻撃・IP spoofing	教材のL4節にも登場するが、**主にL3の脅威**	L3対策表も参照

追加防御：DoS防御サービス、許可リスト・拒否リスト、適切なTLS設定、平文Telnet/FTPの廃止、フィンガープリント対策（不要なバナー・OS情報の露出低減）。URL/URI単位のフィルタは通常L7検査が必要で、純粋なL4ポートフィルタとは区別する。

試験での区別：TCP=信頼性・順序・ACK、UDP=軽量・再送保証なし。ポート=プロセス／サービスの識別、IP=ホスト間配送、MAC=同一リンク配送。

L5〜L7【層の対応早見表・詳細は各節参照】

OSI層	役割	例・注意

OSI層	役割	例・注意
L5 セッション	セッションの確立・維持・終了	セッション管理、再開、認証文脈
L6 プレゼンテーション	表現形式・符号化・暗号化等	文字コード、データ形式、暗号化の概念的整理
L7 アプリケーション	アプリケーション向けネットワークサービス	HTTP(S)、DNS、SMTP、SSH等。Web攻撃や認証の脅威

7. IP通信保護・仮想化・SDN【学習目的に対する補足、教材本文は未読】

テーマ	押さえるべき概念	セキュリティ上の論点
IPsec	IP層での暗号化・認証、VPN	鍵管理、ポリシー、トンネル終端
TLS	アプリケーション通信の保護で広く使用	証明書検証、バージョン、暗号スイート
物理ネットワーク	物理スイッチ・ルータ・ケーブル	物理侵入、機器故障、配線、電源
ネットワーク仮想化	vSwitch、仮想ネットワーク、オーバーレイ	テナント分離、ハイパーバイザ、可視性
SDN	制御プレーンとデータプレーンを論理的に分離し、ソフトウェアで集中制御	コントローラ保護、API認証、単一障害点、設定ミス
マイクロセグメンテーション	ワークロード単位の細かな通信制御	横展開抑止、最小権限、ポリシー管理

L5 セッション層【教材読み上げ完了・2026-10-24追記】

位置づけ・目的：通信するホスト／アプリケーション間の論理的な対話（セッション）を**確立・維持・同期・終了**するための機能を説明するOSI参照モデルの第5層。長時間の対話や処理の継続性が必要な場面で重要。すべての通信が独立したL5機能を必要とするわけではない。

モデルの対応：OSIではL5＝セッション層、L6＝プレゼンテーション層、L7＝アプリケーション層と分ける。一方、一般的な4層TCP/IPモデルではこれらの機能を**アプリケーション層**にまとめる。TCPコネクション（L4）とアプリケーションセッション（L5相当）は同義ではない。後者は認証状態や対話の継続性などを扱い、TCP接続が張り直されても維持される設計がある。

1. 技術・プロトコルと具体例

技術	何をするか	使用場面・具体例	注意点・試験対策
PPP	2点間リンクのカプセル化・リンク確立を行う	旧来のダイヤルアップ、PPPoEなど	**PPP自体は主にL2**。PAP/CHAP等はPPPの認証方式であり、純粋なL5プロトコルではない

技術	何をするか	使用場面・具体例	注意点・試験対策
PAP（Password Authentication Protocol）	ID・パスワードで認証する	旧来のPPP接続	パスワードを暗号化せず送るため盗聴に弱い。避ける
CHAP（Challenge-Handshake Authentication Protocol）	チャレンジと応答値で共有秘密を検証	PPPの認証	パスワード自体の平文送信を避けるが、古い方式・弱い秘密には注意
EAP（Extensible Authentication Protocol）	複数の認証方式を運ぶ拡張可能な枠組み	802.1X、有線LAN、企業Wi-Fi、PPP	EAP自体が単一の暗号化方式ではない。EAP-TLSなど方式ごとに安全性が違う
PEAP（Protected EAP）	TLSトンネル内で内側の認証方式を保護	企業Wi-Fiの802.1X認証	サーバー証明書検証が重要。PEAPとEAP-TLSを混同しない
PPTP（Point-to-Point Tunneling Protocol）	PPPフレームをIPネットワーク経由でトンネル化	旧式のリモートアクセスVPN	MS-CHAPv2等を使う従来構成には深刻な弱点。新規採用を避け、適切な現代的VPNへ
RPC（Remote Procedure Call）	別ホストの処理をローカル関数のように呼び出す	分散システム、Windows RPC、NFS関連の処理	認証・認可、通信保護、公開範囲の制限が重要
TLS	通信相手の認証（主にサーバー）、暗号化、完全性保護を提供	HTTPS、各種アプリケーション通信	「TLSがセッションを扱う」こととOSI L5専用であることは別。複数層にまたがる機能として理解

2. 脅威・攻撃と対策

脅威	攻撃の仕組み・例	主な対策
セッションハイジャック	セッションIDやCookieを奪い、認証済みの対話を乗っ取る	TLS、Secure/HttpOnly/SameSite Cookie、セッションID再生成、短い有効期限、再認証
MITM（中間者攻撃）	通信経路へ割り込み盗聴・改ざん	正しい証明書検証、TLS、相互認証、信頼できる鍵管理（PKI）
ARPポイズニング	偽ARP情報で同一LAN内の通信を迂回させる	Dynamic ARP Inspection、ネットワーク分離、TLS
DNSポイズニング／hostsファイル改ざん	名前解決先を偽装し偽サーバーへ誘導	DNSSECの適切な利用、DNSの構成・監視、端末の変更権限制御、TLS証明書検証
SSHダウングレード	弱いアルゴリズムや設定へ誘導する	SSHv2、弱い暗号・鍵交換方式の無効化、サーバー鍵の検証
MITB（Man-in-the-Browser）	ブラウザ内部のマルウェアが操作や表示を改変	EDR、ブラウザ／拡張機能管理、端末保護、取引内容の別経路確認

脅威	攻撃の仕組み・例	主な対策
トロイの木馬・悪意ある拡張機能	正規ソフトを装い資格情報やセッションを盗む	ソフトウェア許可制、更新、権限最小化、EDR、利用者教育

教材で挙がった対策を横断整理：弱いパスワード認証の廃止、強固なID管理・アクセス制御、PKI、DNSの適切な構成、セッション異常のログ監視とアラート、IDS/IPS。なおIDS/IPSは補助的な検知・防御であり、暗号化済み通信の内部は復号しなければ直接検査できない場合がある。

3. CISSP試験で押さえる論点

- **OSI L5の本質**：セッションの確立・維持・終了（必要に応じて対話制御や同期）。
- **PPP認証の比較**：PAPは平文パスワード送信、CHAPはチャレンジレスポンス、EAPは拡張可能な認証枠組み、PEAPはTLSで内側の認証を保護。
- **安全性の判断**：PPTPは旧式で避ける。TLSと証明書検証はMITM対策の基本。
- **層を混同しない**：ARPはL2、DNSは通常アプリケーション層、SSH/TLSもL5だけに閉じない。教材の「L5の脅威」は**セッション侵害につながる複数層の攻撃**を横断して列挙したもの。
- **ISO 7498-2についての注意**：教材の「セッション層ではセキュリティサービスを提供しない」という記述は、標準全体の一般則として断定しない。ISO 7498-2はセキュリティサービスの配置を複数層にわたって扱う。試験では**実装の機能・保護対象・攻撃経路**を優先して考える。

読み上げ由来の項目：セッション管理、OSIとTCP/IPの差、PAP/CHAP/EAP/PEAP、PPTP、RPC、TLSの層横断性、セッションハイジャック・MITM・ポイズニング・SSHダウングレード・MITB・トロイの木馬、ID管理・PKI・DNS・監視・IDS/IPS。上表の具体例・安全性評価・層分類の訂正は学習用の補足。

L6 プレゼンテーション層【教材読み上げ完了・2026-10-24追記】

目的・背景：異なるコンピューター間でデータの表現形式を統一し、相手が解釈できるようにする。文字コード、データ形式、シリアライズ／デシリアライズ、圧縮／伸長、暗号化／復号を概念上担当する。歴史的には文字集合、数値表現、ワード長などが異なるシステム間の相互運用性が課題だった。TCP/IPの一般的な4層モデルでは独立したL6を設けず、アプリケーション層側でこれらを実装する。

1. 技術と具体例

項目	機能	具体例・注意点
シリアライズ／デシリアライズ	構造化された取引データを送信用バイト列に変換／復元	JSON、Protocol Buffers、ASN.1等。フィールド順序・型・長さ・エンディアンの合意が必要
ASCII	主に英数字・制御文字を表現する7ビット文字集合	日本語など多言語は表現できない
EBCDIC	IBMメインフレーム系で用いられる文字コード	ASCIIとの変換で互換性に注意
Unicode	多言語の文字に符号位置を割り当てる規格	**UnicodeとUTF-8/UTF-16という符号化方式は区別**

項目	機能	具体例・注意点
UTF-8	Unicodeを可変長バイト列に符号化	Webで広く使用、ASCIIと互換的
UTF-16	Unicodeを通常2または4バイトで表現	バイト順やサロゲートペアに注意。「Unicode 16」は厳密にはUTF-16などと表現
圧縮／伸長	転送・保存に必要な容量を減らす	MP3（非可逆音声圧縮）、gzip（可逆圧縮）。圧縮と暗号化は別
暗号化／復号	通信内容の機密性などを守る	TLS（HTTPS等）、S/MIME（電子メールの署名・暗号化）。厳密な実装階層はL6に限定されない
バイト順の変換	複数バイト値の表現順序を統一	ビッグエンディアン／リトルエンディアン

銀行取引の例（教材を整理して再構成）：送信元で①口座名義、口座番号、金融機関識別子、金額、取引日などの入力値を検証→②フィールドと型を確定→③文字コード・数値表現・バイト順を合意形式に変換→④フィールドをシリアライズ→⑤必要に応じ圧縮・暗号化→⑥下位の通信機能へ渡す。受信側では暗号文を復号→必要に応じ伸長→デシリアライズ→文字コードや数値型を受信側表現へ変換→値を検証し処理に渡す。**検証と暗号化の順序、圧縮の有無は実際のプロトコル設計次第**。教材の「ステップ6から1」は受信側の逆変換を表す。

2. 脅威・対策・CIAへの影響

CIA：**C＝機密性、I＝完全性、A＝可用性**。複数に影響する攻撃もある。

脅威・攻撃	仕組み／具体例	主な影響	対策
暗号化通信を使った情報流出	マルウェアがTLS等で持ち出し通信を隠す	C	DLP、送信先・転送量・振る舞いの監視、必要に応じ適法なTLS検査、ゼロトラスト
弱い暗号へのダウングレード	古いTLS版や脆弱な暗号スイートを使わせる	C・I	TLSの安全な構成、旧版・弱い暗号の無効化、証明書検証
SQLインジェクション	入力をSQL構文として解釈させ、不正操作	C・I・A	パラメータ化クエリ、入力検証、最小権限、WAF（補助）
パストラバーサル	`../` 等で許可外のファイルを参照	C・I	パス正規化、許可されたディレクトリへの制限、権限分離
SMB／NetBIOSの悪用	ファイル共有の脆弱性や設定ミスを突く	C・I・A	SMB更新、SMBv1無効化、共有権限の最小化、セグメンテーション
不正なシリアライズデータ	不正な構造や危険なデシリアライズで処理を侵害	I・A・C	安全な形式、型と長さの検証、危険なデシリアライズの回避

脅威・攻撃	仕組み／具体例	主な影響	対策
圧縮爆弾	極端に大きく展開される圧縮データで資源枯渇	A	展開後サイズ・処理時間の制限

教材で挙がった防御策：脆弱な認証・保護機構を使うアプリケーションの更新、アプリケーショントラフィック検査、より安全な保護方式への移行、WAF、アプリケーション配信プラットフォーム（ADP：ロードバランシング等の配信・保護機能を提供する製品群）、ゼロトラストアーキテクチャ。WAFやADPは万能ではなく、脆弱性修正・安全な実装と組み合わせる。

層の注意：SQLインジェクション、パストラバーサルは主として**L7のアプリケーション脆弱性**、SMBはアプリケーション／共有プロトコル、NetBIOSは複数層に関わる。教材は「L6に関連する脅威」として横断的に紹介しているため、OSI分類を厳密な専有層として暗記しない。

3. CISSP試験対策

- L6のキーワード＝**表現形式・文字コード・変換・圧縮・暗号化**。L5＝セッション管理、L7＝ユーザー向けアプリケーションサービスと対比する。
- **暗号化は機密性、デジタル署名／MAC等は完全性や真正性の検証に関連**。暗号化だけで常に完全性が得られるわけではない（AEADなどの方式なら両方を提供）。
- 文字コード変換とデータ圧縮は**セキュリティ機能そのものではない**。
- 教材の「2021年1月のUTF-8採用率96.1%」は**当時の統計値**。現在値として使わない。
- CIA分類は攻撃の直接・間接の影響を区別し、**認証・認可・真正性・否認防止**などCIA以外の保護目標も考慮する。

読み上げから確認した項目：相互運用性、銀行取引の送受信例、ASCII/EBCDIC/Unicode、UTF-8、MP3、SSL/TLS、S/MIME、暗号化を使った流出、NetBIOS/SMB、SQLi、ダウングレード、パストラバーサル、WAF、ADP、ゼロトラスト。具体的な攻撃原理・CIA分類・注意事項は学習補足。

L7 アプリケーション層【教材読み上げ完了・2026-10-24追記】

1. 目的・コンセプトとアーキテクチャ

目的：ユーザー向けソフトウェアがネットワーク上のサービスを利用するための**アプリケーションプロトコルと機能**を提供する。例：ブラウザはソフトウェアであり、HTTP/HTTPSはブラウザが利用するL7プロトコル。TeamsやZoomもソフトウェア全体を「OSI第7層」と同一視しない。実際のソフトウェアは複数層を利用する。多数のプロトコル・入力・ユーザー・公開機能が集まるため攻撃面が広い。

銀行取引との対応：オンラインバンキングの画面や財務ソフト（例：QuickBooks、Excel）がAPIを呼び出し、HTTPS等のL7サービスを利用して取引データを送受信する。L6相当の機能で文字コードやデータ構造を共通形式へ変換し、下位層で配送する。実際のTCP/IP実装ではL5〜L7の機能を厳密に独立したモジュールへ分割する必要はない。

2. 主要プロトコルと仕様

プロトコル	目的・具体例	主なポート・技術仕様	主な脅威・安全策
HTTP	リソースの要求・応答、Web API	TCP/80（HTTP/1.1、HTTP/2の典型）。メソッドGET/POST等、URI、ヘッダー、状態コード	平文盗聴・改ざん、SQLi、XSS。HTTPSへ移行、入力検証
HTTPS	HTTPをTLSで保護。機密性・完全性・サーバー認証	通常443。HTTP/1.1・HTTP/2は主にTCP+TLS、**HTTP/3は QUIC（UDP/443）**	証明書検証、TLS設定、アプリ自体の脆弱性対策。HTTPSだけで安全とは限らない
DHCP（IPv4）	IP、ゲートウェイ、DNS等の設定を動的に配布	**RFC 2131**、UDPサーバー67／クライアント68。DORA手順	Rogue DHCP、DHCP枯渇。DHCP Snooping、監視
DHCPv6	IPv6向け設定配布。SLAACと併用／使い分け	UDPサーバー547／クライアント546、RFC 8415	偽DHCPv6、RA偽装。RA Guard等
RARP	MACからIPを求める旧方式	旧式。BOOTP/DHCPへ移行	現代の新規設計では使用しない
BOOTP	起動時のIP設定等を提供するDHCPの前身	UDP 67/68	動的リースなどはDHCPが拡張
DNS	名前とIP等の情報を対応付ける分散階層型サービス	UDP/TCP 53、FQDN、各種レコード	DNSポイズニング、偽応答。DNSSEC、適切なリゾルバー設定
SNMP	機器の状態取得・管理・通知	UDP 161（要求）、162（Trap/通知）	v1/v2cのコミュニティ文字列、推測・盗聴。**SNMPv3認証・暗号化**、ACL
LDAP	ユーザー・グループ等のディレクトリ情報照会・更新	TCP/UDP 389、LDAPSは通常TCP 636。StartTLS等	LDAPインジェクション、過大な参照権限。TLS、入力処理、最小権限

HTTPの通信例：ブラウザが `GET /accounts HTTP/1.1` のような要求を送り、サーバーは認証・認可やリソース処理の結果をステータスコードと本文で返す。URLのパスが**必ずサーバーの物理ファイルパスに一致するわけではない**（動的ルーティングやAPIがある）。HTMLをブラウザが描画し、JavaScriptを実行する場合がある。JavaとJavaScriptは別物。教材の「HTTP/HTTPSは必ずTCP」はHTTP/3では成立しない。

DHCPのDORA（Discover→Offer→Request→Acknowledgment）：

1. **Discover**：アドレス未取得のクライアントがブロードキャスト等でサーバーを探す（送信元UDP **68** → 宛先UDP **67**）。
2. **Offer**：サーバーが利用可能なアドレスと設定候補を提示（UDP **67→68**）。
3. **Request**：クライアントが選択したオファーを要求する（UDP **68→67**）。
4. **ACK**：サーバーがリースを確定する（UDP **67→68**）。

※DHCPv6はDHCPv4とメッセージ・ポート・仕様が異なる。IPv6はSLAACも利用できる。

3. DNSの階層とレコード

FQDN（Fully Qualified Domain Name）：ルートから完全に指定したドメイン名。例 `www.example.com.` の末尾の `.` はDNSルートを表す。右から**ルート → TLD（com）→ 第2レベル（example）→ 第3レベル（www）**。例 `api.dev.example.com.` の `api` は第4レベル。ルートサーバーはTLDへの委任情報を提供し、個々の全サイトのレコードを一括保持するわけではない。

レコード	用途	例・覚え方
A	名前→IPv4	`www.example.com` → `192.0.2.10`
AAAA	名前→IPv6	`2001:db8::10`
CNAME	別名→正規名	`shop` → `web.example.com`
MX	メール受信サーバー	メール配送先と優先度
PTR	IP→名前（逆引き）	逆引きDNS
SRV	サービスのホスト・ポート	ディレクトリサービス等の発見
NS	ゾーンの権威DNSサーバー	委任先
SOA	ゾーンの管理情報	管理元、シリアル番号、各種タイマー

DNSのセキュリティ：DNSSECはDNS応答の真正性・完全性検証を支援するが、通信内容を暗号化する仕組みではない。DoT/DoHはクライアントとリゾルバー間の通信を暗号化する技術で、DNSSECとは役割が異なる。

4. SNMP・LDAPの構造

SNMP構成要素：**NMS（Network Management System）が監視・管理する。管理対象デバイス（ルーター、スイッチ等）上のエージェント**が情報を提供する。**MIB（Management Information Base）**は管理対象情報の構造・定義を記述し、OIDで項目を識別する。SNMPv1/v2cのコミュニティ文字列は強固な認証ではなく、平文送信され得る。SNMPv3の認証・プライバシー保護、管理ネットワークの分離、アクセス制限を優先。

LDAPの識別名：例 `cn=Yamada,ou=Sales,dc=example,dc=com`。

属性	意味	例
DN	Distinguished Name：エントリの完全な識別名	`cn=Yamada,ou=Sales,dc=example,dc=com`
RDN	Relative Distinguished Name：親に対する相対名	`cn=Yamada`
CN	Common Name：一般名	`cn=Yamada`
OU	Organizational Unit：組織単位	`ou=Sales`
DC	Domain Component：ドメイン構成要素	`dc=example,dc=com`

ディレクトリにはアカウントやグループ情報など機密性の高い情報が集まる。認証・認可基盤と密接に結びつくため、アクセス権の最小化、TLS、監査、LDAP検索式の安全な構築が重要。

5. 「レイヤー8」は必要か

OSIの正式な第8層は存在しない。教材が扱うのは、L1〜L7の通信機能モデルに**人、組織運用、アプリケーションの構成管理、ガバナンス、サプライチェーン、クラウドプラットフォーム、ライフサイクル管理**まで含めるべきかという議論。

- **否定的な見方**：OSI/TCP/IPは通信の責務を分割するモデルであり、組織・人間・調達・アプリケーション全体まで取り込むと境界が曖昧になる。
- **肯定的な見方**：実際の事故は人的判断・構成ミス・ソフトウェア供給網・運用不備にも依存する。ネットワークの安全性を総合的に捉える便宜的な層が有用。
- **CISSPでの整理**：レイヤー8は比喩。**ガバナンス、教育、構成管理、サプライチェーンリスク、ゼロトラスト**を通信プロトコルの外側も含めて扱う。

6. 脅威・対策とCIA

攻撃・脅威	仕組み／具体例	CIAへの主な影響	主な対策
SQLインジェクション	不正入力がSQL構文として実行される	C・I・A	パラメータ化クエリ、最小権限、WAF補助
TLSダウングレード	弱いTLS版・暗号方式に誘導	C・I	安全なTLS構成、旧版無効化、証明書検証
不正DHCP（Rogue DHCP）	偽サーバーが不正なGW・DNSを配布	C・I・A	DHCP Snooping、ポート制御、監視
DNSポイズニング	偽の名前解決で攻撃先へ誘導	C・I	DNSSEC、リゾルバー保護、TLS検証
LDAPインジェクション	LDAP検索条件を不正操作	C・I	安全なフィルタ構築、入力検証、最小権限
SNMP悪用	デフォルトのコミュニティ文字列や管理権限を悪用	C・I・A	SNMPv3、ACL、管理網分離、不要機能停止
HTTP Flood DDoS	大量のWebリクエストで処理資源を枯渇	A	CDN、レート制限、ボット対策、DDoS緩和
パラメーター改ざん	金額・権限・対象IDなどを改変して送信	C・I	サーバー側認可・検証、改ざん検知
XSS（クロスサイトスクリプティング）	不正なスクリプトを利用者ブラウザで実行	C・I	文脈別出力エスケープ、CSP、Cookie保護
セッションハイジャック	Cookieやトークンを盗み利用者になりすます	C・I	TLS、Cookie属性、トークン管理、再認証
マルウェア	不正コードを配布・実行し情報窃取等	C・I・A	EDR、更新、ソフト制御、教育、監視

教材の対策を網羅：危険サイトへのアクセス監視・ブロック、悪性・疑わしいボットの制御、強力なアクセス制御、アプリケーショントラフィックの詳細検査、安全なアプリケーション保護への移行、**WAF**、**ADP（アプリケーション配信プラットフォーム）**、ゼロトラスト、エンドユーザーのセキュリティ教育・意識向上。

層をまたぐ点に注意：TLS、DHCP、DNS、セッション乗っ取り等は複数層に関連する。攻撃の発生箇所と被害を受けるサービスを分けて理解する。

7. CISSP直前チェック

- **L7＝ネットワークサービスのプロトコル**。ブラウザやTeamsそのものと区別。
- **HTTPは平文、HTTPSはTLSで保護**。ただしHTTPSでもSQLiやXSSは防げない。
- **HTTP/3はQUIC/UDP**。HTTPは必ずTCPという旧教材の記述は現代では不正確。
- **DHCP：DORA／RFC 2131／UDP 67・68**。DNS：A/AAAA/CNAME/MX/PTR/SRV/NS/SOA。
- **SNMP：NMS・MIB・エージェント・管理対象デバイス**。LDAP：DN・RDN・CN・OU・DC。
- **レイヤー8は非公式**。人・運用・ガバナンスまで含めた議論。

銀行取引を例にしたOSI全7層のエンドツーエンド通信（総合チートシート）

例：利用者がブラウザでオンラインバンキングにログインし、振込依頼をHTTPSで送信する。以下は**理解のためのOSI概念モデル**。実際にはL5〜L7がアプリケーション側で一体化し、HTTP/3ではL4の扱いが異なる。

OSI層	送信側：振込依頼を出すまで	受信側：銀行サーバーでの処理	代表技術・機器	主な保護目標・対策
L7 アプリケーション	ブラウザが振込先・金額をHTTPリクエストとして送信	Web/APIが認証・認可、取引の整合性、残高などを検証	HTTPS、Web API、WAF	**I・C**：サーバー側検証、MFA、認可、監査
L6 プレゼンテーション	取引情報をJSON等に整形・UTF-8で符号化、TLSで暗号化	TLSを復号、文字列・数値を正しく解釈	UTF-8、JSON、TLS	**C・I**：暗号化、完全性保護、形式検証
L5 セッション	ログイン状態・セッショントークンを管理	トークンを検証し正規の利用者の対話に紐づける	Cookie、セッション管理	**C・I**：セッション保護、失効・再認証
L4 トランスポート	TCPのポート443宛てにセグメント化し、順序・再送を制御	TCPを再構成してアプリへ渡す	TCP、ポート、L4 FW	**A・I**：接続保護、DoS緩和、FW
L3 ネットワーク	宛先IPアドレスに向けルーティング	IPパケットを受け取り上位へ渡す	IP、ルーター、ACL	**A・C**：経路保護、送信元検証、ACL
L2 データリンク	次ホップのMACアドレスを使ってフレーム化	宛先MACを確認しフレームを受信	Ethernet、ARP、スイッチ	**C・I・A**：DAI、802.1X、VLAN、ポート保護
L1 物理	電気・光・電波としてビットを伝送	信号をビット列へ復元	ケーブル、光ファイバー、無線	**A・C**：物理保護、冗長化、盗聴防止

送信時の順序：L7 → L6 → L5 → L4 → L3 → L2 → L1。**受信時**：L1 → L2 → L3 → L4 → L5 → L6 → L7。実際のTCP/IPスタックでは各OSI機能が必ず独立した処理段階として実装されるわけではない。

CIAの覚え方：盗聴・情報流出→主に**C（機密性）**、改ざん・偽取引→主に**I（完全性）**、DDoS・断線→主に**A（可用性）**。銀行取引ではさらに**真正性、認可、否認防止、監査可能性**が重要。

8. 試験直前チートシート

問われたら	答えの軸
OSIとTCP/IPの違い	7層の参照モデル vs 実装に近い4層のプロトコルモデル
OSI L5〜L7はTCP/IPのどこ？	アプリケーション層
OSI L1〜L2はTCP/IPのどこ？	ネットワークインターフェース（リンク）層
IPアドレス	L3／ネットワーク層
MACアドレス	L2／データリンク層
ポート番号	L4／トランスポート層
ビット	L1／物理層
フレーム	L2／データリンク層
パケット	L3／ネットワーク層
セグメント	L4／TCP
カプセル化	上位データへ各層の制御情報を付加
ベストエフォート	IP自体は配送保証をしない
HazardとThreat	教材では非意図的事象と意図的攻撃を区別。ただし定義は文脈依存
APT	高度・持続的・標的型の攻撃活動
キルチェーン7段階	偵察→武器化→配信→悪用→インストール→C2→目的実行
C2	攻撃者が侵害環境へ指令を送る仕組み
LotL	正規ツールを悪用して活動
L2の典型攻撃	ARP spoofing、MAC flooding、VLAN hopping
L3の典型攻撃	IP spoofing、経路偽装
IPsec	IP層で通信保護
SDN	制御プレーンとデータプレーンの分離
セキュリティ設計	アプリケーションを重視しつつ全層で多層防御

9. 今後追記する項目のチェック

- [ ] L2の実際の教材本文・専門用語（音声文字起こし欠落分）
- [ ] L3ネットワーク層の教材本文
- [x] L4・L5の教材読み上げ内容を統合
- [x] L6の教材読み上げ内容を統合
- [x] L7の教材読み上げ内容を統合
- [ ] IP通信プロトコル保護の進化
- [ ] 仮想ネットワークと物理ネットワークの比較

- ☐ SDNの教材本文
- ☐ 4.1以降の各節

整理方針：読み上げで確認できた事項と、CISSP試験対策としての補足を区別し、未読部分を「完了」とは扱わない。

OSI L1〜L7 脅威×CIA×対策 チートシート（L1〜L7統合版）

層	技術・プロトコル例	攻撃例／仕組み	主なCIA影響	主な対策
L1 物理	ケーブル、電波、リピーター	盗聴、切断、妨害電波	C・A	施錠、配線保護、冗長化、電波対策
L2 データリンク	Ethernet、MAC、ARP、VLAN	ARP偽装で通信迂回、MACフラッディング	C・I・A	DAI、ポートセキュリティ、802.1X、VLAN設計
L3 ネットワーク	IP、ICMP、OSPF、BGP	IP偽装、Smurf、経路乗っ取り	C・I・A	ACL、送信元検証、経路認証、レート制限
L4 トランスポート	TCP、UDP、ポート	SYN Floodで接続資源枯渇、ポートスキャン	A（偵察はCIA直接侵害とは限らない）	SYN Cookies、レート制限、FW、DDoS対策
L5 セッション	セッション管理、認証、RPC	セッションID窃取、MITM	C・I	セッション保護、強固な認証、TLS、監視
L6 プレゼンテーション	Unicode、圧縮、TLSの暗号化機能	弱い暗号へのダウングレード、危険なデシリアライズ	C・I・A	強い暗号設定、入力検証、更新、DLP
L7 アプリケーション	HTTP、DNS、SMTP、SQL	SQLi、XSS、パストラバーサル	C・I・A	パラメータ化クエリ、出力エスケープ、WAF、最小権限

覚え方：CIAは攻撃ごとに単一の正解を固定するものではない。たとえば盗聴は主にC、改ざんはI、通信停止はA。認証回避・なりすましは真正性やアクセス制御にも関係する。複数層にまたがる攻撃は「主要な侵害箇所」と「影響を受ける層」を分けて考える。

更新方針：OSI全7層の読み上げを反映。今後の教材内容に応じて技術仕様、攻撃・対策・CIA対応を随時精緻化する。

Domain 4 — 4.1 後半：ネットワーク技術・クラウド・監視・ゼロトラスト【2026-10-24追記】

> 範囲：4.2に入る直前までの読み上げ内容。既存のOSI L1–L7の解説を保持し、その後の項目を統合した。以下の具体例・仕様補足は試験学習用の説明であり、教材の逐語的な転載ではない。

1. レガシープロトコルとリモートアクセス

技術	代表的ポート・役割	セキュリティ論点／推奨
FTP	TCP 21制御、TCP 20はアクティブモードの典型的データ送信元。ファイル転送	通常は平文。SFTP（SSH上、通常TCP 22）またはFTPS（TLS）を利用。SFTPとFTPSは別技術
Telnet	TCP 23、遠隔端末	認証情報・通信が平文。SSHへ移行
Finger	TCP 79、ユーザー情報照会	利用者列挙・情報漏えい。原則無効化
IRC	TCP 6667が慣用的、TLSは6697など	チャット。なりすまし、スクリプト悪用、ソーシャルエンジニアリング、ボットネットC2に悪用され得る。ネットスプリットはサーバー間接続の分断
rlogin	TCP 513、遠隔ログイン	旧式の信頼関係・平文通信。SSHへ
rsh / rcp	TCP 514（rshサービス）。遠隔シェル／コピー	ホスト信頼の悪用、盗聴。SSH / SCP / SFTPへ
X11	GUI表示のネットワークプロトコル。TCP 6000番台を使用する構成もある	ネットワーク越しのX11公開は危険。SSH転送や適切な認証・アクセス制限
SSH	TCP 22が通常。安全な遠隔操作・トンネリング	ホスト鍵検証、強固な認証、鍵管理、パッチ、権限最小化が必要

CISSPの判断軸：旧式・平文・信頼ベースのリモート操作は機密性・真正性・完全性に問題。SSHへの移行だけでなく、管理ネットワーク分離、MFA、ログ、最小権限を組み合わせる。IRCのSPIM（インスタントメッセージの迷惑送信）、偽装、悪意あるスクリプトは利用者とシステム双方への脅威。

2. IPsecの構造、AHとESP、IKE、NAT-T

項目	要点	注意
AH（Authentication Header）	パケットの完全性・データ起点認証、リプレイ対策。**暗号化しない**	IPヘッダーの認証対象フィールドがNATで変更されると検証に失敗しやすい
ESP（Encapsulating Security Payload）	ペイロードの機密性（暗号化を選択した場合）、完全性・認証、リプレイ対策を提供可能	現代のVPNではESPが一般的。ESPでも認証・暗号化の具体的提供範囲はSAのアルゴリズム構成次第
IKE / IKEv2	セキュリティアソシエーション（SA）と鍵のネゴシエーション	UDP 500、NAT-T時は通常UDP 4500。DH/ECDH、証明書・PSK等の認証
NAT-T	ESPをUDP 4500でカプセル化しNAT/NAPTを通過	NAT環境でESPの扱いを改善。AHをNAT対応に変えるわけではない
L2TP/IPsec	L2TPのトンネリングをIPsecで保護	L2TP単体に暗号化機能はない。L2TPは通常UDP 1701
KINK	Kerberized Internet Negotiation of Keys、Kerberosを用いるIPsec鍵管理方式	IKEと異なる歴史的な方式。実務で一般的とは限らない

ESP構造：ESPヘッダー（SPI・シーケンス番号）→ペイロード→トレーラー→認証データ（構成による）。SPIは受信側でSAを識別するために用いる。**トランスポートモード**は主にIPペイロードを保護し、元のIPヘッダーは基本的に残る。**トンネルモード**は元のIPパケット全体をカプセル化し、新しい外側IPヘッダーを付与する。拠点間VPNではトンネルモードが典型。

攻撃・CIA・対策：盗聴（C）→ESP暗号化、改ざん（I）→完全性検証、リプレイ（I／認証）→シーケンス番号とアンチリプレイ、鍵窃取（C/I）→強固な鍵管理・認証、VPNゲートウェイ障害（A）→冗長化・監視。IPsecは可用性を自動保証しない。

3. マルチレイヤープロトコル、コンバージドネットワーク

TCP/IP通信は、アプリケーションデータをTCP/UDP、IP、リンク層へと**カプセル化**して転送する。セキュリティ機能や脅威はOSIの単一層に閉じない。複数プロトコル・管理インターフェースを重ねると攻撃面が増え、複雑な障害切り分けが必要になる。

コンバージェンス：VoIP（音声をIPネットワークで運ぶ）、FCoE（Fibre ChannelフレームをEthernetで運ぶ）など、異なる用途の通信を共通基盤に統合。機器・運用コストを減らせる一方、帯域競合、遅延・ジッター、共通障害、横展開リスクに注意。QoS、ネットワーク分離、冗長化、監視が重要。産業制御（OT）では可用性・安全性への影響も重視。

4. SDN、NFV、SD-WAN

SDN（Software-Defined Networking）：ネットワークの**制御判断（コントロールプレーン）**と**パケット転送（データプレーン）**を論理的に分離し、ソフトウェアからプログラム可能にするアーキテクチャ。OSI/TCP-IPの通信階層モデルの代替ではない。

構成	役割	接続
アプリケーションプレーン	ネットワークに必要なポリシー・要求を表す	ノースバウンドAPIで制御側へ
コントロールプレーン	経路・ポリシー・転送ルールを決定	サウスバウンドAPI（例：OpenFlow）で機器へ
データプレーン	決定済みルールに従って実パケットを転送	—

「集中制御」は**論理的集中**であり、物理コントローラーが必ず一台という意味ではない。SDNのセキュリティはコントローラーの認証・認可、API保護、変更監査、冗長化、プレーン間通信保護、設定の整合性が鍵。

NFV（Network Functions Virtualization）：FW、ルーター等のネットワーク機能を汎用基盤上で仮想化する。SDN（制御の仕組み）とNFV（機能の実行形態）は別概念で、組み合わせ可能。AWSリージョンは地理的区分、VPCは論理ネットワークであり、どちらもSDNの3プレーンそのものではない。

製品・サービス例：Cisco ACI（データセンターのポリシーベース制御）、VMware NSX（仮想ネットワーク・細粒度の通信制御）、Cisco Catalyst SD-WAN（拠点間通信の集中管理）、AWS VPC（ソフトウェア定義の仮想ネットワークを利用する身近な例。ただしVPC自体がSDNコントローラーという意味ではない）。

SD-WAN：SDN的な集中ポリシー管理を広域ネットワークに応用。MPLS、ブロードバンド、インターネット等の複数回線を活用し、アプリケーション特性・遅延・損失・可用性に応じて経路を選択。回線費用・拠点展開負荷の削減や性能改善が期待できる。トラフィックの**論理分離**は可能だが、厳密なワークロード単位のマイクロセグメンテー

ションが標準で必ず実現するとは限らない。クラウドホスト型の制御基盤も、冗長化・バックアップ・障害時切替の設計なしに高可用性が保証されるわけではない。

試験の対比：SDN＝ネットワーク制御、NFV＝ネットワーク機能の仮想化、SD-WAN＝WANのポリシー制御。利点は一貫性・柔軟性・自動化、リスクは制御基盤への依存・API侵害・誤設定の広域波及。

5. CDN（Content Delivery Network）

利用者に近い**エッジ拠点**から画像・動画・静的資産等をキャッシュ配信し、遅延とオリジン負荷を低減する。例：Amazon CloudFront、Cloudflare。可用性向上、トラフィック吸収、製品によってDDoS対策・WAF連携が可能。

脅威と対策：キャッシュ汚染・機密データの誤キャッシュ（C/I）→Cache-Control・キャッシュキー設計、オリジンへの直接攻撃（A/C/I）→オリジン到達制限・認証、TLS誤設定（C/I）→証明書管理・HTTPS強制。CDNの導入のみでオリジンの安全性は保証されない。

6. VPC、セキュリティグループ、NACL、アカウント分離

VPC（Virtual Private Cloud）はクラウド内の論理的に分離されたネットワーク。サブネットはVPCのIPアドレス範囲を分割した単位で、ルートテーブル等を使って通信を設計する。DNS名・タグはリソース発見や管理に役立つが、それ自体がセキュリティ境界を保証するものではない。

AWSでの仕組み	適用範囲	ステート	ルール	ポイント
セキュリティグループ（SG）	ENI（ネットワークインターフェース）単位。EC2等に関連	**ステートフル**	**許可のみ**	許可済み通信の戻りは自動許可。複数SGを適用可能
ネットワークACL（NACL）	**サブネット単位**	**ステートレス**	**許可・拒否**	往路・復路を別々に評価。ルール番号順に評価
アカウント分離	管理・権限・課金などの境界	該当なし	IAM等で制御	本番・開発を別アカウントにすると管理上の分離を強化

重要：SG/NACLの上記仕様は**AWSの実装例**であり、クラウド全般の普遍的仕様とは限らない。SGはVMそのものではなく、より正確にはENIに関連付ける。異なるVPCでも接続設定や共有権限があれば通信可能であり、**VPC分離とアカウント分離は異なる。**別アカウントでもクロスアカウントIAMや共有ネットワークの設定を誤れば境界が弱まる。

VPCとVPNの区別：VPC＝クラウド内の論理ネットワーク、VPN＝暗号化等で保護された仮想的通信経路を構成する技術。

7. ネットワーク監視と管理

活動	実施内容	主なCIA観点
継続的監視・監査	特権操作・構成変更・通信ログの記録、SIEM等による相関分析、正常ベースラインからの逸脱検知	C/I/A
インシデント対応	検知、トリアージ、封じ込め、根絶、復旧、教訓の反映。人員・手順・ツールを事前整備	C/I/A

活動	実施内容	主なCIA観点
コントロールの有効性評価	導入したFW、IDS/IPS、アクセス制御が運用中も有効か継続確認	C/I/A
構成・パッチ管理	機器の資産台帳、承認済み構成ベースライン、変更監査、脆弱性・パッチ対応	I/A（Cにも影響）
多層防御・IAM	RBAC、最小権限、MFA、管理経路の分離、職務分掌	C/I
キャパシティ管理	帯域、CPU、メモリ、セッション数、ストレージ、しきい値と増強計画	**A**

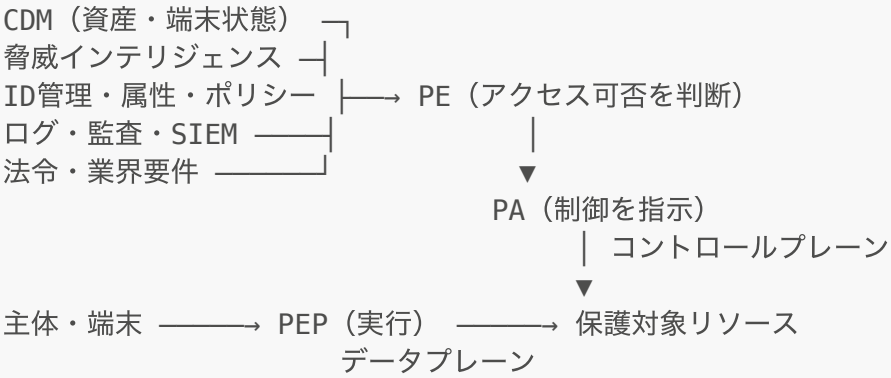
試験での考え方：対策は「導入」して終わりではなく、**運用中に有効性を検証し、変更に追従させる。**RBACは職務・役割に権限を付与する仕組み。キャパシティ監視は可用性確保の予防的管理。

8. ゼロトラストアーキテクチャ（ZTA）

NIST SP 800-207 — Zero Trust Architecture（2020年）。従来の「社内ネットワーク内は信頼」という前提に依存せず、**リソースへのアクセス要求を主体・端末・状況・ポリシーに基づき評価**する。単一の製品やMFA導入だけでゼロトラストが完成するわけではない。

構成要素	機能
PE：Policy Engine	アクセス可否を決定する
PA：Policy Administrator	PEの決定を受け、通信経路の確立・終了などを指示する
PEP：Policy Enforcement Point	実際にアクセスを許可・遮断し、主体とリソースの通信を仲介する

論理ビュー（概念）：



CDM＝Continuous Diagnostics and Mitigation。端末の健全性・脆弱性・資産状態等の継続的な把握。**脅威インテリジェンス**＝攻撃者・悪性IP・新規脅威等の外部／内部情報。**アクティビティログ**＝行動履歴やアクセス履歴。これらはPEの判断を補強する情報源。

SDNとの違い：SDNのコントロールプレーンはネットワーク転送ルールを決める。ZTAのコントロールプレーンはアクセス許可・通信確立の意思決定を担う。用語が同じでも対象が異なる。

CISSPの判断軸：明示的検証、最小権限、継続的な状態評価、侵害前提、ログとポリシーの一貫性。コントロールプレーンやPEPが侵害されれば広域に影響し得るため、強固な認証、可用性、変更管理、監査を適用。

9. 規格・ガイドライン・RFC横断チートシート（4.1時点）

番号・名称	主題／何を覚えるか	関連Domain
NIST SP 800-207 — Zero Trust Architecture	ZTAの基本概念、PE/PA/PEP、アクセス判断の情報源	D1・D4
NIST SP 800-37 — Risk Management Framework for Information Systems and Organizations	RMFのライフサイクル、継続的監視	D1・D4
NIST SP 800-53 — Security and Privacy Controls for Information Systems and Organizations	セキュリティ／プライバシー管理策カタログ	D1・D4
RFC 4301 — Security Architecture for the Internet Protocol	IPsecのアーキテクチャ、SA、モード	D4
RFC 4302 — IP Authentication Header	AHの仕様	D4
RFC 4303 — IP Encapsulating Security Payload (ESP)	ESPの仕様	D4
RFC 7296 — Internet Key Exchange Protocol Version 2 (IKEv2)	IKEv2によるSAと鍵のネゴシエーション	D4
RFC 3948 — UDP Encapsulation of IPsec ESP Packets	NAT-TのESP/UDPカプセル化	D4
ISO/IEC 7498-2 — OSI Security Architecture	OSIにおけるセキュリティサービスとメカニズムの整理	D1・D4

※ Domain 1との統合時は、正式名称、規格の目的、適用範囲、重要用語、似た文書との差を並べて最終チートシートにする。規格の存在と、法的な強制力・個別組織への適用義務は区別する。

10. 4.1 最終暗記チェック

- **OSI / TCP-IP**：通信機能の階層モデル。**SDN**：ネットワーク制御の設計思想。**SD-WAN**：WANに応用。
- **SDNの3プレーン**：アプリケーション要求 → コントロール判断 → データ転送。Northbound/SouthboundはAPIの向き。
- **IPsec**：AHは暗号化しない。ESPは暗号化・完全性などを提供可能。IKEv2は鍵・SAを交渉。NAT-TはUDP 4500。
- **CDN**：近いエッジから配信、遅延・負荷を削減。キャッシュとオリジンの保護に注意。
- **AWS VPC**：SG＝ENI・ステートフル・許可のみ。NACL＝サブネット・ステートレス・許可／拒否。
- **管理境界**：VPC分離とアカウント分離は別。最小権限とIAMの管理も必要。
- **監視・管理**：ログ、トリアージ、構成／パッチ、RBAC/MFA、多層防御、容量監視。導入後の有効性検証が重要。
- **ZTA**：NIST SP 800-207。PEが判断、PAが指示、PEPが実施。CDM・ログ・脅威情報が判断材料。

4.2 安全なネットワークコンポーネント（Secure Network Components）

> 学習目標：ネットワークデバイスの進化とセキュリティへの影響、およびコンピューターハードウェアの安全なアーキテクチャと設計を理解する。以下は読み上げ内容を整理し、仕様・具体例・CISSP上の注意点を補足したもの。

1. ハードウェアの運用：信頼の起点（Root of Trust）

1.1 OSより下の信頼が重要な理由

アプリケーションはOSに、OSはファームウェア・ブートローダー・ハードウェアに依存する。起動時の低レイヤーが侵害されると、OS上のウイルス対策だけでは発見・防御が難しい。そこで、**Root of Trust（RoT、信頼の起点）**として、起動や鍵管理などの重要処理の基礎となる、信頼できる最小のハードウェア／ファームウェア機能を設ける。

用語	意味	具体例・注意点
Root of Trust（RoT）	他のコンポーネントの信頼性を検証する起点	変更困難なROMコード、ハードウェアの鍵、TPMなど。実装によって構成が異なる
Trust Anchor（トラストアンカー）	検証の出発点として事前に信頼する鍵・証明書等	ファームウェア署名検証に使う公開鍵、認証局のルート証明書
BIOS / UEFI	OS起動前にハードウェアを初期化し、ブート処理を進める	Secure Bootで署名を検証できる構成がある。BIOS/UEFI自体も更新・保護が必要
TPM（Trusted Platform Module）	ハードウェアベースの鍵保護、暗号処理、起動状態の測定値保存等	BitLockerの鍵保護、PCR（Platform Configuration Register）による測定結果の記録
Secure Boot	署名を検証し、未承認のブートコンポーネントの実行を防ぐ仕組み	**実行を制御**する。TPMのMeasured Boot（起動状態を測定・記録）とは区別
不変性（immutability）	信頼の起点が容易に改変されない性質	ROM、書き込み保護、ハードウェア保護された鍵。**RoTのすべてが完全な読み取り専用である必要はない**

「TPMに鍵を焼き込む」の意味：製造時に一意の秘密情報をTPM内に生成・格納し、通常のソフトウェアから秘密鍵そのものを読み出せないようにする、という意味で使われることが多い。たとえばTPMの**Endorsement Key（EK）**は製造時に用意される場合がある。ただし、**すべての鍵が製造時に固定されるわけではない**。TPMは運用時にも鍵を生成・保護できる。署名や復号などの処理をTPM内で行い、秘密鍵の外部流出を抑制する。

例：PCの起動：①UEFIが署名済みブートローダーを検証（Secure Boot）→②起動コンポーネントの測定値をTPMのPCRへ記録（Measured Boot）→③ディスク暗号化の鍵解放条件を起動状態に結び付ける（例：BitLocker）。署名検証・測定・鍵解放はそれぞれ異なる機能。

ユーザーモードとカーネルモード：ユーザーモードの通常アプリは権限が制限される。カーネルモードはメモリ・デバイス等へ広範にアクセスできる特権実行領域。**カーネル権限の侵害は被害が大きい**が、カーネルモードそのものがRoTを意味するわけではない。

脅威とCIA：ブートキット・ファームウェア改ざん（I、C）、秘密鍵流出（C・真正性）、起動不能（A）。対策は署名検証、TPM、ファームウェア更新、物理保護、鍵のライフサイクル管理、構成監査。

2. インフラの運用・伝送メディア

冗長電源：UPS、二重電源、別系統給電などで単一障害点を減らす。重要なのは単に電源ユニットを2個付けるだけでなく、電源供給経路・UPS・配電盤・保守計画を含めて可用性を設計すること。詳細な環境設計は後続節と関連する。

伝送メディアの信号低下：銅線の減衰・ノイズ、光ファイバーの損失・曲げ・コネクタ汚れなどで品質が低下する。タップ挿入・不正接続によって信号特性が変化する場合もあるが、**信号低下だけで盗聴や侵入と断定できない**。ケーブル試験、光パワー測定、エラーカウンタ、ポート監視、変更管理、物理アクセス制御を組み合わせて判断する。

観点	例	主要なCIA
盗聴・不正タップ	無許可の分岐、物理アクセス	C
物理損傷・ノイズ	断線、減衰、CRCエラー、再送増加	A、I
電源・機器障害	スイッチ停止、回線断	A

3. NAC（Network Access Control）の目的と仕組み

NACは「誰が・何を使い・どの状態で・どこへ接続するか」をポリシーに基づいて判定・執行する仕組み。BYOD、IoT、医療機器、ゲスト、契約業者、モバイル端末の増加で重要になった。**ポリシーを決めるのは組織の管理者・リスクオーナーであり、NAC製品はそのポリシーを執行する**。

3.1 NACの処理フロー

1. **発見・識別**：接続端末、ユーザー、場所、接続ポート、端末種別を把握。
2. **認証（Authentication）**：利用者または端末の身元を確認。802.1X/EAP、証明書、RADIUS等。
3. **姿勢評価（Posture Assessment）**：OSパッチ、EDR/AV、ディスク暗号化、FW、MDM登録、構成状態を確認。
4. **認可（Authorization）**：ポリシーに応じてアクセス先・権限を決定。VLAN、ACL、セキュリティグループ等を適用。
5. **隔離・修復（Quarantine/Remediation）**：非準拠端末は修復用ネットワークへ。パッチ・AV・設定を更新。
6. **再評価・監視**：準拠後に許可し、接続中も必要に応じて再認証・変更・強制切断。
7. **終了・クリーンアップ**：セッション終了時に割当権限・一時設定・記録を整理。

例：社員の私物PCが社内Wi-Fiに接続 → 証明書が無効またはEDR未導入 → 業務LANを拒否して修復ネットワークへ → 条件を満たせば限定的に接続許可。**IoT・医療機器**はエージェント導入が難しい場合があり、パッシブ識別・MAB（MAC Authentication Bypass）・専用セグメント等を組み合わせる。ただしMACアドレスは偽装できるため、MABを強固な認証と同等に扱わない。

3.2 IEEE 802.1X と RADIUS

役割	構成要素	何をするか
Supplicant	接続を求める端末	認証情報を提示する
Authenticator	スイッチ、無線AP	認証が終わるまでポートの通常通信を制限し、認証メッセージを中継する

役割	構成要素	何をするか
Authentication Server	RADIUSサーバー（例：Cisco ISE）	認証結果や適用ポリシーを返す

流れ：端末とスイッチ/APの間はEAP over LAN（EAPOL）。AuthenticatorはRADIUSを使って認証サーバーとやり取りする構成が一般的。RADIUSは従来UDP 1812（認証）・1813（アカウンティング）が典型。EAP-TLSでは証明書ベースの相互認証が可能。**802.1Xはポートベースのネットワークアクセス制御であり、通信内容そのものを自動的に暗号化する規格ではない。**

Cisco Identity Services Engine（ISE）：認証・認可・端末可視化・姿勢評価・ゲスト管理・ネットワーク機器へのポリシー配布等を支援するNAC/ID管理基盤の例。**業界の製品例であって、唯一の標準規格ではない。**EDR、DLP、NGIPS、脅威インテリジェンス等の情報と連携し、検知時に隔離・再認可する設計もある。

NACの限界：接続時の合格だけで安全を保証しない。内部侵害、認証済み端末のマルウェア感染、管理基盤の障害に備え、継続評価・ログ・セグメンテーション・冗長化を併用する。

4. エンドポイントセキュリティ

機能	実装・具体例	保護対象
発見・列挙・ID管理	資産台帳、証明書、許可／拒否端末ベースライン	真正性、C/I
構成・パッチ管理	OS・アプリ・ファームウェア更新、暗号化、設定ベースライン	I/A
ヘルス・姿勢検証	EDR稼働、AV更新、FW有効化、脆弱性評価	C/I/A
行動モデリング	EDR/UEBA、管理者端末の異常操作検知	C/I
所有・物理セキュリティ	紛失・盗難対策、資産管理、施錠、ディスク暗号化	C/A
リモート管理	MDM/UEM、ポリシー適用、リモートロック／ワイプ	C/I
位置情報	紛失端末の探索、地域・条件付きアクセス	C、プライバシー

BYODの注意：個人端末への管理機能・位置情報取得・ワイプは、事前の同意、目的限定、データ分離、法令・プライバシーポリシーへの適合が必要。管理者権限があっても無制限の監視を正当化しない。

5. NACフレームワークの比較

名称	提唱・背景	特徴	現在の位置づけ
Cisco NAC（CNAC / Cisco NAC Architecture）	Cisco	ネットワーク接続時の端末検査、ポリシーに基づく許可・隔離。Cisco NAC Appliance等の歴史的実装	**旧来のアーキテクチャ／製品系統。**現代のCisco製品例はISE
Microsoft NAP（Network Access Protection）	Microsoft	Windows端末の健全性確認、ポリシー準拠によるアクセス制御	**廃止されたレガシー技術。**現行の標準選択肢として推奨しない

名称	提唱・背景	特徴	現在の位置づけ
TCG TNC（Trusted Network Connect）	Trusted Computing Group	ベンダー横断で端末の健全性・ネットワーク接続を評価するアーキテクチャ／仕様群	概念・標準化の比較対象。TCGは組織名、TNCは仕様群

覚え方：Cisco＝ベンダー実装、NAP＝Microsoftの旧方式、TNC＝TCGの標準化アプローチ。**802.1Xはアクセス制御の基盤規格**であり、これらと同一のものではない。

6. NAC導入のベストプラクティス

1. **ポリシーを先に策定**：対象利用者・端末、社員・ゲスト・契約業者、社給・BYOD、許容するアクセス範囲、例外、責任者を明確化。
2. **必要なセキュリティ状態を定義**：ディスク暗号化、画面ロック、AV/EDR、FW、OS更新、証明書、MDM登録。
3. **資産と通信のベースライン確立**：何が・誰が・どのポート／SSID／場所から接続しているかを把握。管理不能IoT等も分類。
4. **リスクに応じて製品・構成を選択**：既存のIAM、RADIUS、スイッチ、AP、MDM、EDR、SIEMとの相互運用性を評価。
5. **段階導入**：可視化・監視のみ → 限定セグメントで強制 → 全社展開。業務停止リスクと例外処理を検証。
6. **検疫と修復を用意**：非準拠端末を単純に遮断するだけでなく、安全な修復経路を設ける。
7. **監査・インシデント対応へ接続**：認証失敗、ポリシー違反、端末状態変更、隔離・復旧をログに記録。アラート、SIEM、対応手順に統合。
8. **継続的改善**：誤検知、バイパス、可用性、構成ドリフトを検証し、ポリシーを更新。

CISSPの優先順位：まず組織の方針・リスク・対象資産を定義し、次に技術を選ぶ。「製品を入れれば安全」ではない。CIS Controlsの考え方とも整合する**資産の把握、継続的なログ・監査、管理策の有効性検証**が重要。

7. PAT（Port Address Translation）

PATはNATの一形態で、**複数の内部IPアドレス／セッションを、単一または少数の外部IPアドレスと異なるポート番号に対応付ける。**一般にNAPT（Network Address and Port Translation）とも呼ぶ。

例：内部端末A `192.168.1.10:50001` と端末B `192.168.1.11:50001` が外部Webサーバーへ接続すると、NAT装置はそれぞれ `203.0.113.5:40001` と `203.0.113.5:40002` のように変換し、変換テーブルで戻り通信を識別する（IPは説明用アドレス）。

比較	NAT（広義）	PAT / NAPT
変換対象	IPアドレス等	IPアドレス**とポート番号**
主な用途	アドレス空間の変換	多数の内部端末でグローバルIPv4アドレスを共有
注意点	端末間の直接接続を複雑化	セッション数・ポート枯渇、ログ追跡の必要性

セキュリティ注意：PATは内部アドレスを直接公開しにくくするが、**ファイアウォール・認証・暗号化の代わりではない。**ログには変換前後のIP・ポート・時刻が必要。主な影響は可用性（ポート枯渇）、追跡性（ログ不足）。

8. プロキシファイアウォール

プロキシはクライアントとサーバーの**間に入り、代理で通信を確立・中継**する。接続の分離、アクセス制御、ログ、必要に応じたコンテンツ検査が可能。**フォワードプロキシ**は利用者側の代理、**リバースプロキシ**はサーバー側の代理（WAF、負荷分散等で利用）。

項目	サーキットレベルプロキシ	アプリケーションレベルプロキシ
主な判断対象	セッション／接続の確立、宛先・ポート等	HTTPなどアプリケーションのメッセージ・要求内容
典型例	SOCKSプロキシ（実装によりTCP/UDP対応）	HTTPプロキシ、リバースプロキシ、アプリケーションゲートウェイ
強み	比較的低い処理負荷、アプリ非依存で中継しやすい	URL・ヘッダー・内容等を踏まえた細かなポリシー、検査・ログ
弱み	ペイロードを詳細解析しないため悪意ある内容を見逃し得る	解析コスト、対応プロトコル、暗号化通信の可視性・プライバシーへの配慮が必要
主要なCIA	接続制御でC/I/Aを支援するが内容検査は限定的	悪性コンテンツや情報流出への対策でC/Iを支援、過負荷対策でA

例：社内端末が外部Webサイトへアクセス → フォワードHTTPプロキシがURL・認証・カテゴリを確認して中継。公開Webサイトの手前ではリバースプロキシ／WAFがHTTP要求を検査してWebサーバーへ転送。

注意：「アプリケーションプロキシならバッファオーバーフローを必ず防げる」わけではない。シグネチャ・構文検証・脅威検知機能の実装と設定に依存する。HTTPSの内容検査はTLS終端・復号が必要な場合があり、証明書管理・個人情報保護・通信性能に影響する。

9. 4.2 脅威・CIA・対策チートシート

対象	攻撃・障害例	主な影響	対策
RoT/ファームウェア	ブートキット、署名検証回避、鍵窃取	C/I/A、真正性	Secure Boot、TPM、署名、更新、物理保護
カーネル	権限昇格、悪意あるドライバー	C/I/A	権限分離、ドライバー署名、パッチ、監視
伝送媒体	不正タップ、断線、信号劣化	C/A	物理保護、測定、変更監査、冗長化
NAC/802.1X	MAC偽装、認証情報窃取、非準拠端末の接続	C/I、真正性	EAP-TLS、姿勢評価、検疫、再認証、ログ
エンドポイント	マルウェア、紛失、パッチ未適用	C/I/A	EDR、MDM、暗号化、構成管理、リモートロック
PAT/NAT	ポート枯渇、変換ログ欠落	A、追跡性	容量監視、ログ、FW、セッション制限
プロキシ	コンテンツ検査回避、誤設定、過負荷	C/I/A	アプリ層検査、最小権限、可用性設計、監査

10. 4.2 CISSP最重要ポイント・確認問題

- **RoTは信頼の出発点**。TPMは鍵保護や測定値管理を行うが、すべての鍵が製造時に焼き込まれるわけではない。
- **Secure Boot＝署名に基づく実行制御、Measured Boot＝起動状態の測定記録**。両者を混同しない。
- **カーネルモードは高権限の実行モード**。RoTそのものではない。
- **NACはポリシーを執行**する。まず方針・対象・準拠条件を決め、認証・姿勢評価・認可・検疫・修復を設計。
- **802.1Xの3者**：Supplicant → Authenticator → Authentication Server（通常RADIUS）。
- **Cisco NAC、Microsoft NAP、TCG TNC**は背景・位置づけが異なる。Microsoft NAPは旧技術。
- **PATはIP＋ポート変換**。FWや暗号化の代替ではない。
- **サーキットレベルプロキシは接続中心、アプリケーションレベルプロキシは内容検査が可能**。検査性能は実装次第。

理解確認：①起動時の署名検証と測定はどう違う？ ②NACが端末を隔離する条件は誰が決める？ ③802.1Xでスイッチ/APはどの役割？ ④PATがあってもFWが必要な理由は？ ⑤HTTPSの中身をプロキシで検査する際の課題は？

4.3 設計に従って安全な通信チャネルを実装する

> **学習目的**：従来の通信インフラ、VoIP、リモートアクセス、仮想化されたネットワーク、サードパーティー接続について、通信方式・実装例・脅威・CIAへの影響・適切な対策を評価する。以下は読み上げ内容に技術的補足と必要な訂正を加えた学習ノート。

1. VoIP（Voice over Internet Protocol）

VoIPは音声をデジタル化・符号化してIPネットワークで運ぶ技術。従来のPSTN（Public Switched Telephone Network、公衆交換電話網）と異なり、音声・データを共通のIP基盤で扱える。IP電話機、ソフトフォン、IP-PBX、SIPトランク、PSTNゲートウェイを組み合わせて構成する。

構成要素	役割	具体例・補足
SIP（Session Initiation Protocol）	通話の確立・変更・終了などの**シグナリング**	`INVITE` → `180 Ringing` → `200 OK` → `ACK`、終了時`BYE`。通常UDP/TCP 5060、TLS利用時は通常TCP 5061
SDP（Session Description Protocol）	コーデック・IP・メディアポートなどを交渉	SIPメッセージ本文などで利用。**SDP自体は音声を運ばない**
RTP / RTCP	RTPは音声・映像のリアルタイム配送、RTCPは品質統計・制御	多くの構成でUDPを使用。RTPは通常、暗号化しない
SRTP	RTPメディアの暗号化・完全性保護	鍵交換方式（DTLS-SRTP等）も重要
TLS	SIPなどのシグナリングを保護	**SIP over TLSだけではRTP音声は暗号化されない**
コーデック	音声の符号化・圧縮、必要帯域・音質・遅延に影響	G.711（比較的高帯域・低圧縮）、G.729（圧縮）、Opus（可変ビットレート・低遅延）
IP-PBX / SBC	内線制御、外部接続境界の保護	Asterisk、Cisco Unified Communications Manager、AudioCodes等

構成要素	役割	具体例・補足
PSTNゲートウェイ	IP電話と従来の電話網を相互接続	SIPトランクとPSTNの相互接続

規格：SIPの初期仕様は**RFC 2543（1999年）**。現行の基本仕様は**RFC 3261**（RFC 2543を置換）。RTPはRFC 3550、SRTPはRFC 3711。**VoIP全体がRFC 2543だけで標準化されたわけではない。**

実際のサービス：Zoom、Microsoft Teams、Webex、各種クラウドPBXなど。Skypeは歴史的な代表例（一般向けSkypeは2025年に終了）。これらは必ずしも全通信を標準SIP/RTPだけで構成するわけではなく、独自の会議制御・メディア転送方式を併用する。

利点（よいニュース）：アクセス制限、会議参加認証、待機室、録音・監査ログ、データ保持ポリシー、暗号化設定などを統合管理しやすい。電話とチャット・画面共有・録画を統合できる。

リスク（悪いニュース）：不正な会議参加、アカウント乗っ取り、録音データ流出、SIP認証への総当たり、SIP偽装、通話盗聴、メディア経路のDoS、端末マルウェア、暗号実装の欠陥やサービス提供者の鍵アクセス。**「暗号化あり」＝「エンドツーエンド暗号化」ではない。**政府等がすべての製品の暗号を解読できると一般化しない。

対策：SIP over TLSとSRTPの適切な構成、SBC、強固な認証/MFA、最小権限、会議設定・録音のガバナンス、QoS、ネットワーク分離、更新管理、ログ監視。盗聴は主に**機密性（C）**、なりすまし・改ざんは**完全性（I）**、音声断・DoSは**可用性（A）**。

2. コンバージドプロトコル：iSCSI・CAPI・CXL

コンバージド（収束）は、従来別々の用途だった通信・計算・ストレージ等を共通の接続基盤で扱う方向性。必ずしも「すべてTCP/IP上」という意味ではない。

2.1 iSCSI（Internet Small Computer Systems Interface）

SCSIのブロックストレージコマンドを**TCP/IP上にカプセル化**し、サーバー（**Initiator**）から遠隔ストレージ（**Target**）をローカルディスクのように利用する。一般的なTCPポートは**3260**。NASのファイル共有（SMB/NFS）と異なり、通常は**ブロック単位**でアクセスする。

通信例：仮想化ホスト → iSCSI Initiator → ストレージ専用VLAN/ネットワーク → iSCSI Target → LUN。製品例：Synology/QNAPのiSCSI Target、TrueNAS、Windows Server iSCSI Target、VMware ESXiのSoftware iSCSI Adapter、NetAppストレージ（対応状況は製品構成による）。

認証：CHAP（片方向／相互CHAP）が代表的。KerberosやSRP（Secure Remote Password）は歴史的仕様・選択肢として学ぶが、**一般的なiSCSI製品が必ず対応するとは限らない。**認証と通信暗号化は別問題。IPsec等を使わない構成では機密性保護が不十分になり得る。

攻撃・対策：認証情報漏えい、Targetなりすまし、ストレージ改ざん、DoS、横展開。専用セグメント、ACL、強いCHAP認証、暗号化、LUNマスキング、パッチ、ストレージ側の権限分離。基本仕様の例はRFC 3720（旧）、RFC 7143（統合・更新）。

2.2 CAPIとCXLを混同しない

技術	概要	代表例	セキュリティ論点

技術	概要	代表例	セキュリティ論点
CAPI（Coherent Accelerator Processor Interface）	IBM POWER系のCPUとアクセラレーターをキャッシュコヒーレントに接続する技術	IBM POWER8関連のCAPI対応環境、後継のOpenCAPI関連技術	アクセラレーターへのメモリアクセス権限、ファームウェア信頼性
CXL（Compute Express Link）	PCIeの物理基盤を活用し、CPU・アクセラレーター・メモリ拡張デバイスを高効率に接続する標準	CXL対応サーバー、メモリ拡張モジュール（Samsung等が製品開発）	DMA・メモリ隔離・デバイス認証・ファームウェア更新

背景：CPUのクロック速度向上だけでは熱・消費電力の制約が大きく、マルチコア化、アクセラレーター活用、メモリ共有の高速化が重要になった。

CXLのプロトコル	主な役割	イメージ
CXL.io	デバイスの検出、構成、I/O、管理	PCIeに近い制御・I/O経路
CXL.cache	デバイスがホストメモリをキャッシュコヒーレントに利用	アクセラレーターがCPU側のメモリを効率的に参照
CXL.mem	ホストCPUがデバイス側メモリにアクセス	CXLメモリ拡張・プーリング

試験観点：CXLはネットワークのIP通信プロトコルではなく、**高速相互接続・メモリ共有の技術**。共有範囲が広がるほど、デバイスの信頼性、IOMMU、DMA保護、分離境界の設計が重要。

3. トランスポートアーキテクチャ

3.1 トポロジーと3つのプレーン

物理トポロジーはケーブル・機器の接続形態、**論理トポロジー**はデータがどう流れるか。スター、リング、バス、メッシュなどは4.1のOSI物理層と関連する。

プレーン	何をするか	具体例	脅威・対策
データプレーン	実際のパケット/フレーム転送	スイッチのASICによる転送、ルーターのフォワーディング	DDoS、盗聴、転送ポリシー回避 → ACL、QoS、レート制限
コントロールプレーン	経路・トポロジー情報を決定	OSPF、BGP、ルーティングテーブルの生成	経路注入・隣接関係の乗っ取り → ルーティング認証、フィルタ、CoPP
マネジメントプレーン	構成変更、監視、管理者アクセス	SSH、SNMPv3、管理API、NETCONF	管理資格情報の侵害 → 管理網分離、MFA、RBAC、監査

SDNとの関係：SDNはコントロールの集中化・プログラム制御を特徴とする設計思想。ここでの3プレーンの分類は**通常のルーター/スイッチにも存在**し、SDN専用ではない。

3.2 転送戦略の比較

方式	動作	長所	短所	適用イメージ
カットスルー（Cut-through）	フレーム全体の受信を待たず、宛先MAC等を読んで転送開始	低遅延	破損フレームも転送し得る。エラーや輻輳時に不利	低遅延重視のスイッチング
ストアアンドフォワード	フレーム全体を受信・検査してから転送	FCS検証、破損フレームの破棄	フレーム長に応じた遅延	一般的なEthernetスイッチ
アダプティブ	ネットワーク状態に応じて方式を切替	遅延と信頼性のバランス	実装が複雑	対応機器の最適化

※ここはOSI L2の**Ethernetフレーム**を対象に説明するのが正確。破損フレームの再送は、上位プロトコルや端末の仕組みに依存する。

3.3 パフォーマンスメトリクス（必須4項目）

指標	意味・単位	悪化すると	改善策
帯域幅（Bandwidth）	理論上の伝送容量。bps/Mbps/Gbps	混雑・転送時間増大	増速、QoS、トラフィック制御
レイテンシ（Latency）	データ到達までの遅延。ms	会話の応答遅れ、操作遅延	経路短縮、輻輳抑制、近接配置
ジッター（Jitter）	パケット間の到着時間の揺らぎ。ms	VoIPの音切れ・映像の乱れ	ジッターバッファ、QoS、混雑抑制
信号対雑音比（SNR）	信号電力と雑音電力の比。通常dB	誤り増加、無線速度低下、再送	干渉源除去、適切な配置・チャネル・配線

試験ポイント：帯域幅が十分でも、ジッターや遅延が大きければVoIPの品質は悪い。SNRは高いほど一般に有利だが、測定条件・方式にも依存。

4. 物理的セグメンテーションと独立した多層防御

- **インバンド管理**：本番トラフィックと同じネットワーク経由で管理。低コストだが本番網の障害・侵害に巻き込まれやすい。
- **アウトオブバンド（OOB）管理**：本番網とは独立した管理経路。例：専用管理LAN、シリアルコンソール、Ciscoのコンソール接続、HPE iLO、Dell iDRAC。障害時の復旧・インシデント対応に有利。
- **エアギャップ（Air gap）**：保護対象を外部ネットワークから物理的・運用的に隔離する方式。オフラインバックアップ、重要制御システム等で使用。ただしUSBや保守作業等を通じた侵入はあり得る。
- **オフラインバックアップの注意**：古いバックアップには未適用パッチ・脆弱なソフトウェアが含まれる場合がある。復元時は隔離環境で検証・修復し、必要な更新を適用してから本番接続。
- **多層防御の独立性**：複数の対策が同じ認証基盤・電源・管理ネットワークに依存すると**共通原因故障（Common-mode failure）**を招く。例：SSO障害で多数の業務システムに同時にアクセスできなくなる。冗長性、非常用アクセス、障害ドメイン分離を検討。

- **鍵配布**：対称鍵を別経路（OOB）で配ることは有効な場合があるが、**常にOOBが必須というわけではない。**認証済みの鍵交換（例：TLS、IKE）でも安全な鍵確立が可能。
- **物理セキュリティ**：入退室ゲート・ICカード・監視カメラ・侵入センサー、火災検知・消火設備を連携。火災被害低減と復旧時間短縮を可用性（A）および費用対効果の観点で評価。
- **Northbound/Southboundの用語注意**：SDNのAPI方向を表す場合と、データセンター内の通信方向を表す場合がある。**方角自体がセキュリティ境界を意味するわけではない。**管理網・本番網を無条件にブリッジしないことが重要。

5. 論理的セグメンテーション

技術	仕組み	具体例・注意点
DMZ	外部公開サービスを内部ネットワークから分離	公開WebサーバーをDMZ、DBを内部ネットワークに配置
VLAN（802.1Q）	L2ブロードキャストドメインを論理分割	社員用、ゲスト用、IoT用を分離。**VLANだけではL3通信制御を保証しない**
VRF（Virtual Routing and Forwarding）	同一ルーター内に独立したL3ルーティングテーブルを複数保持	企業合併時の重複RFC1918アドレス、通信事業者の顧客分離
ACL / FW / マイクロセグメンテーション	セグメント間の通信を必要最小限に制限	Web→DBの必要なポートだけ許可

VRFとVLANの違い：VLANは主に**L2の分割**、VRFは**L3の経路表の分離**。VRF間で通信するには明示的な経路リークやFW等の設計が必要。VRF自体が暗号化するわけではない。

6. Wi-Fi・Bluetooth・WAPの保護

6.1 Wi-Fi規格と認証

IEEE 802.11はWi-Fiの無線LAN技術規格群。**IEEE 802.1X**は有線・無線で使う**ポートベースのネットワークアクセス認証**。数字が似ているが目的が異なる。

用語	役割・特徴	セキュリティ上の注意
IEEE 802.11	無線LANのMAC/PHY	Wi-Fi規格群。暗号・認証方式は世代や構成に依存
IEEE 802.1X	Supplicant / Authenticator / 認証サーバーによるアクセス制御	企業向けWPA2/WPA3-Enterprise等で利用。通常EAPを運ぶ
EAP	認証方式を拡張できる枠組み	EAP自体が単一の暗号方式ではない
PEAP	TLSトンネル内で内側の認証を行う方式	サーバー証明書の適切な検証が重要
LEAP	Cisco由来の旧EAP方式	オフライン辞書攻撃等の問題があり**非推奨**
EAP-TLS	クライアント証明書とサーバー証明書による相互認証	証明書ライフサイクル管理が必要だが強力
WPA2/WPA3	Wi-Fiの認証・暗号化方式群	WPA3-Enterprise、802.1X、適切な証明書検証を検討

無線特有の脅威：盗聴・パケットスニッフィング（C）、Evil Twin/不正AP・中間者攻撃（C/I）、ジャミング・無線DoS（A）、デフォルト管理者資格情報の悪用（C/I/A）。DVR、Webカメラ、スマートスピーカー等のIoTがボットネット化され、DDoSに悪用されることもある。

6.2 Bluetooth

Bluetoothは**短距離無線接続**技術。Bluetooth ClassicとBLEなどで特性・用途が異なる。一般的な利用例：イヤホン、キーボード、センサー、スマートフォン連携。**30フィート ≒ 9.14メートル**。ただしこれは一つの目安で、Bluetoothの到達距離は出力クラス・環境・方式によって大きく変わる。

利点	制約・脅威	対策
AP不要で機器間接続可能、低消費電力の用途もある	2.4GHz帯でWi-Fi等と干渉、方式により速度・距離が制限	適切なペアリング、不要時無効化、更新、接続許可管理
モバイル/IoTと親和性が高い	不正ペアリング、情報漏えい、Bluejacking/Bluesnarfing等	発見可能モード制御、暗号化、認証

6.3 WAP（Wireless Access Point）

WAP/APは無線端末をLANに接続する**無線アクセスポイント**。多くは802.11無線とEthernetの間をL2でブリッジする。家庭用「無線ルーター」はAPとL3ルーターを一体化した製品だが、**APそのものを必ずルーターとみなすのは不正確**。

キャプティブポータル：ホテル、空港、飲食店などで、利用規約同意・ゲスト登録・決済・認証画面に誘導してからインターネット接続を許可する仕組み。**ポータルだけでは無線通信の暗号化や端末の健全性を保証しない**。必要ならWPA2/WPA3、802.1X、NAC/MDMを併用。

WAP保護の実務チェック：

1. RFサイトサーベイ・無線侵入検知（WIDS/WIPS）で不正AP・Evil Twinを調査。
2. AP/WLCログを監視し、異常接続・認証失敗を検知。
3. 端末のパッチ、暗号化、EDR、データ整合性等をNAC/MDMで検証。非準拠端末は隔離。
4. ゲストWi-Fiの利用可能エリアと社内網へのアクセス範囲をポリシー化。
5. 営業時間外の利用制限やAP管理を検討。ただし業務継続要件との整合が必要。
6. AP管理パスワード変更、管理インターフェース分離、ファームウェア更新、WPS無効化、適切な無線暗号化を実施。

7. リモートアクセス、仮想デスクトップ、VPN

リモートアクセスは社外・自宅・移動中の端末から組織資産へ接続する仕組み。管理できないネットワーク・端末・物理環境を前提に、ユーザーと端末を別々に評価する。

共通リスク：人的ミス・不用意な情報共有、全OSI層にわたるネットワーク脆弱性、攻撃者による高価値標的化、実装・設定の複雑さ。対策はMFA、端末健全性、最小権限、アクセスログ、条件付きアクセス、パッチ管理、ゼロトラストの継続的検証。

7.1 リモート会議・仮想アプリケーション/デスクトップ

方式・製品例	概要	セキュリティ上のポイント

方式・製品例	概要	セキュリティ上のポイント
Citrix Virtual Apps and Desktops	アプリケーション/デスクトップを遠隔配信	画面・入力・クリップボード・印刷の制御
Microsoft Azure Virtual Desktop / Windows 365 / RDS	仮想デスクトップ・リモートセッション	ID保護、MFA、セッション管理、データ持ち出し制限
VNC（Virtual Network Computing）	画面転送によるリモート操作	実装によって暗号化が弱い/ない。VPNやSSHトンネル等で保護
SSH v2	安全な遠隔シェル・トンネル	鍵検証、公開鍵認証、強固な設定
Telnet	旧式の平文遠隔端末	原則使用しない

7.2 VPNとトンネリング

VPN（Virtual Private Network）は共有ネットワーク上に論理的なプライベート接続を構成する技術。**トンネリング**は元の通信を別のプロトコルで包んで運ぶこと。**トンネルを作ることと暗号化することは別**。

技術	仕組み	セキュリティ・ポート
PPTP（Point-to-Point Tunneling Protocol）	PPPをGRE等でトンネル化する旧方式	旧認証・暗号の問題があり**使用非推奨**。制御TCP 1723、GRE（IPプロトコル47）
L2TP（Layer 2 Tunneling Protocol）	L2フレームをIPネットワーク上でトンネル化	**L2TP単体に暗号化はない**。通常UDP 1701。IPsecと組み合わせる
L2TP/IPsec	L2TPのトンネルをIPsecで保護	IKE UDP 500、NAT-T UDP 4500等。暗号・認証設定が重要
IPsec VPN	L3でIPパケットを認証・暗号化する方式	ESP（IPプロトコル50）、IKEv2、トンネル/トランスポートモード。4.1参照
TLS VPN（旧称SSL VPN）	TLSで安全な通信路を確立。ブラウザー型・クライアント型など	通常TCP 443等。実装によってはDTLS/UDPも使用。**古いSSLは非推奨**
WireGuard	比較的新しいVPNトンネル実装	UDPベース、公開鍵暗号を使用。例：Linux、対応ルーター/製品
OpenVPN	TLSを利用するVPNソフトウェア	TCP/UDP構成可。認証・証明書・設定管理が重要

重要な訂正：すべてのVPNが「元のIPパケット全体を暗号化する」とは限らない。トンネルの種類・VPN方式・モードにより暗号化範囲が異なる。またTLS VPNは一般にPKI/証明書を利用できるが、**すべてがクライアント証明書による認証を必須とするわけではない**。

ファイアウォールとトンネリング：HTTP CONNECT、TLS、P2P等が許可ポートに隠れて流れる可能性がある。デフォルト拒否、アプリケーション識別、プロキシポリシー、必要な通信だけの許可、ログ分析を組み合わせる。ただし業務上必要なチャットを一律に禁止すると、シャドーITや危険な回避策を誘発し得るため**安全な代替手段を提供**する。

7.3 在宅勤務（Telework）とスクリーンスクレイパー

在宅勤務の確認事項：安全な接続（VPN/ZTNA）、MFA、OS/EDR更新、会社管理端末、家庭用ルーター設定、機微情報の分類・共有範囲、画面の覗き見、同居人や来訪者のアクセス、紙資料・印刷物・録音の扱い、紛失時の報告手順。

スクリーンスクレイパー（Screen Scraper）は表示画面の情報を読み取り・抽出するプログラム。正当なRPAやアクセシビリティ用途もあるが、マルウェアが画面上の機微情報、認証コード、顧客データ等を盗む用途にも使われる。画面共有・VDIでもスクリーンショットや外部カメラによる持ち出しは完全には防げない。対策は権限管理、DLP、端末監視、透かし、画面共有ポリシー、ユーザー教育。

8. マルチメディアコラボレーション、P2P、IM

マルチメディアコラボレーションは音声・映像・画面共有・チャット・ファイル共有などを統合する仕組み。例：Microsoft Teams、Zoom、Webex、Slack（音声/会議機能を含む）。録画・議事録・外部ゲスト・外部アプリ連携・クラウド保存を一体でリスク評価する。

P2P（Peer-to-Peer）は各ノードがクライアントにもサーバーにもなり得る分散型の通信方式。例：BitTorrent、分散型通信システム。中央管理が難しく、ファイル共有による情報漏えい・著作権問題・マルウェア流通に注意。

P2Pボットネットでは制御ノードの冗長化・動的な役割変更により、単一のC2サーバー停止だけでは駆除が難しい場合がある。「プライマリ/セカンダリ」構造は**特定の実装例**であり、全P2Pネットワークの必須構造ではない。

IM（インスタントメッセージング）の類型	通信のイメージ	特徴・リスク
P2P型	端末間の直接通信	中央監査やデータ保護が難しい場合がある
ブローカー型	メッセージ仲介サービスが配送・キューイング	仲介者への依存、認証、保持期間の設計
サーバー中心型	中央サーバーを通じて通信	一元管理しやすい一方、集中障害・侵害が広範囲に影響

※実際の製品は複数方式を組み合わせることがあり、この3類型は理解のための概念的整理。

対策：承認済み製品の利用、ゲスト制限、DLP、保存・監査設定、E2EEの有無と鍵管理、端末制御、フィッシング教育、脆弱性管理。IM経由のSPIM（インスタントメッセージスパム）にも注意。

9. 回線の仮想化：回線交換・パケット交換・仮想回線

比較軸	回線交換（Circuit Switching）	パケット交換（Packet Switching）
通信経路	通信前に専用回線/リソースを確立	データをパケットに分割して共有網で転送
帯域	確保された帯域を利用しやすい	他利用者と共有し効率的
品質	予測可能な遅延・帯域を提供しやすい	輻輳・経路変化で遅延や順序が変動し得る
障害	確立経路の障害に影響される	再ルーティングで耐障害性を得られる場合がある

比較軸	回線交換（Circuit Switching）	パケット交換（Packet Switching）
例	POTS（従来電話）、専用T/E回線等	IPネットワーク、インターネット

注意：IPパケットは異なる順序で届き得るが、順序保証を行うかは上位プロトコル次第。**TCPは順序付きバイトストリームを提供するが、UDP自体は順序保証しない。**また回線交換も物理故障や設計条件によってQoSが絶対保証されるわけではない。

トラフィックシェーピング：送信速度を平滑化し、帯域使用と輻輳を制御。QoSはシェーピングだけでなく分類・優先制御・ポリシング・予約などの組合せで設計する。

仮想回線（Virtual Circuit）

共有ネットワーク上に**論理的な接続経路**を構成し、専用回線に似た通信サービスを提供する。

方式	経路確立	例	注意点
PVC（Permanent Virtual Circuit）	事前にプロビジョニングされ継続的に存在	Frame RelayのPVC、ATM PVC	通信ごとに設定しないが、物理専用回線とは異なる
SVC（Switched Virtual Circuit）	必要時に動的に確立し終了後解放	X.25のSVC、ATM SVC、ISDNの呼設定に類似する考え方	接続確立のオーバーヘッドがある

MPLSとの関係：ラベルスイッチングでLSP（Label Switched Path）を形成する点は仮想回線に似るが、**MPLSのLSPを常にSVCと同一視しない。**静的/動的設定など方式が異なる。Frame RelayのPVCとIPのスタティックルートも同一技術ではない。

10. NFV（Network Functions Virtualization）

NFVはファイアウォール、ルーター、IDS/IPS、NAT、ロードバランサー、DNS関連機能等を**専用ハードウェアから切り離し、汎用サーバー/仮想化基盤上のソフトウェア（VNF）として実装**する考え方。運用・スケール・更新の柔軟性を高める。

概念	役割	例
NFV	ネットワーク機能をソフトウェア化・仮想化	仮想ファイアウォール、仮想ルーター
VNF（Virtual Network Function）	仮想化された個々の機能	Cisco CSR 1000v（歴史的例）、仮想Palo Alto NGFW、FortiGate-VM
NFVI	VNFを動かす計算・ストレージ・ネットワーク基盤	仮想化ホスト、仮想スイッチ
MANO	VNFのオーケストレーション・管理	配備、スケーリング、監視、ライフサイクル管理
ETSI	NFVアーキテクチャや管理の標準化を推進	ETSI NFV ISG

SDNとの違い：SDNは**制御と転送の分離・プログラム可能なネットワーク制御**、NFVは**ネットワーク機能のソフトウェア実装。**両者は補完的であり、どちらか一方だけでも成立する。

脅威・対策：ハイパーバイザー侵害、テナント間漏えい、オーケストレーター乗っ取り、設定誤り、リソース競合。管理API保護、強い分離、署名済みイメージ、構成管理、監視、容量計画、最小権限が重要。

11. サードパーティー接続

組織は通信事業者、クラウド事業者、委託先、保守ベンダー、取引先等と直接・間接に接続する。接続の利便性だけでなく**サプライチェーン/第三者リスク**として評価する。

管理段階	実施事項	具体的な統制
ポリシー策定	接続の申請・承認・オンボーディング・監視・変更・終了条件を規定	接続目的、責任分界、データ分類、許可プロトコル、アクセス期限
棚卸しとリスク評価	既存の接続関係を一覧化し、リスクの高いものを特定	接続先、資産、権限、扱うデータ、委託先評価、契約条件
契約と継続監視	契約・SLA・セキュリティ要件に沿って運用を監査	MFA、専用接続/セグメント、ログ、脆弱性対応、インシデント通知
オフボーディング	契約終了時にアクセスを確実に撤去	アカウント無効化、VPN/鍵/証明書失効、ルール削除、データ返却・消去

CIAへの影響：第三者経由のデータ流出（C）、設定改ざん・不正操作（I）、接続先の障害による業務停止（A）。**接続を許す前にリスクを評価し、最小権限で許可し、継続的に検証する。**

12. 4.3 横断チートシート：規格・RFC・試験頻出比較

規格・仕様	対象	覚えるポイント
RFC 2543 / RFC 3261	SIP	初期仕様と後継の基本仕様
RFC 3550	RTP	音声・映像などのリアルタイム配送
RFC 3711	SRTP	RTPメディアの暗号化・認証
RFC 3720 / RFC 7143	iSCSI	SCSIをTCP/IP上で運ぶ
IEEE 802.11	Wi-Fi	無線LAN規格
IEEE 802.1X	ネットワークアクセス制御	ポートベース認証、EAP、RADIUS
IEEE 802.1Q	VLAN	L2タグ付け
ETSI NFV	NFV	NFVアーキテクチャ・管理の標準化
IPsec関連RFC（例：RFC 4301、RFC 7296）	IPsec / IKEv2	安全なL3通信と鍵交換（4.1参照）

CISSPの判断軸：

1. **VPN ≠ 必ず暗号化**：PPTP・L2TP・TLS VPN・IPsec VPNの保護範囲を区別。

2. **SIP ≠ 音声データ**：SIPは呼制御、RTPはメディア、SRTPはメディア保護。
3. **VLAN ≠ VRF**：L2分離とL3ルーティング分離。
4. **SDN ≠ NFV**：制御方式の設計と機能の仮想化。
5. **Cut-through ≠ Store-and-forward**：低遅延とフレーム検査のトレードオフ。
6. **回線交換 ≠ 仮想回線**：物理的な専用資源と共有網上の論理経路を区別。
7. **OOB管理 ≠ エアギャップ**：別管理経路とネットワークからの隔離。
8. **キャプティブポータル ≠ 無線暗号化**：利用制御と無線保護は別。
9. **セキュリティ製品はポリシーの代替ではない**：リスク評価・ポリシー・実装・監視・改善を一貫して設計。
10. **CIAと復旧可能性を総合評価**：機密性だけでなく、音声品質、管理系の可用性、第三者障害も考慮。

理解確認：①SIPをTLS化しても盗聴対策が不十分な場合がある理由は？ ②iSCSIのCHAPと通信暗号化の違いは？ ③CXL.memとCXL.cacheの違いは？ ④データ/コントロール/管理プレーンを狙う攻撃を一つずつ挙げよ。⑤VRFとVLANの分離対象は？ ⑥PVCとSVCはいつ経路を確立する？ ⑦NFVとSDNを組み合わせる利点は？ ⑧サードパーティーの契約終了時に失効すべきものは？

4.3までの読み上げ内容を反映済み。 Domain 4（4.1〜4.3）の通読・試験対策用として継続更新する。